In the Light and in the Shadows: Human-Centered Analysis in Cybercrime

by

Zhibo Sun

A Dissertation Presented in Partial Fulfillment
of the Requirements for the Degree
Doctor of Philosophy

Graduate Supervisory Committee:

Gail-Joon Ahn, Co-Chair
Adam Doupé, Co-Chair
Tiffany Bao
Victor Benjamin

ARIZONA STATE UNIVERSITY

May 2022

ABSTRACT

Studies on underground forums can significantly advance our understanding of cybercrime workflow and underground economies. However, research on underground forums has concentrated on public information with little attention paid to users' private interactions. Since detailed information will be discussed privately, the failure to investigate private interactions may miss critical intelligence and even misunderstand the entire underground economy.

Furthermore, underground forums have evolved into criminal freelance markets where criminals trade illicit products and cybercrime services, allowing them to launch sophisticated cyber attacks. However, current research rarely examines and explores how criminals interact with each other to create new cybercrime models, which makes us miss the opportunities to detect new cybercrime patterns proactively.

Moreover, in clearnet, criminals are active in exploiting human vulnerabilities to conduct various attacks, and phishing attacks are one of the most prevalent cybercrimes. It has been discovered that educating humans is an effective method against these human-centric attacks, and phishing awareness training has been proven to decrease the rate of clicking phishing emails. However, the rate of reporting phishing attacks is unexpectedly low based on recent studies, leaving phishing websites with hours of additional active time before being detected.

In this dissertation prospectus, I first present an analysis of private interactions in underground forums and introduce machine learning-based approaches to detect hidden connections between users. Secondly, I discuss an emerging sophisticated scam service in underground forums that exploits the return policies of online retailers to defraud them. Finally, I present my ongoing work in which I will conduct a comprehensive evaluation of the phishing reporting ecosystem to identify the critical challenges while reporting phishing attacks.

TABLE OF CONTENTS

Page

LIST OF TABLES vi

LIST OF FIGURES viii

CHAPTER

1 INTRODUCTION 1

2 BACKGROUND 6

2.1 Underground forums. 6

2.2 Social engineering. 8

2.3 Phishing. 8

3 PRIVATE INTERACTIONS IN UNDERGROUND FORUMS 11

3.1 Introduction 11

3.2 Motivating Example and Data Overview 14

3.2.1 Motivating Example 14

3.2.2 Data Overview and Preprocessing 16

3.3 Private and Public Message Analysis 17

3.3.1 Content and Purpose 17

3.3.2 Artifacts 20

3.3.3 Private Message Recipients Behavior 21

3.4 Detecting Private Interactions in Underground Forums 26

3.4.1 Approach Overview 26

3.4.2 Testing Results 28

3.5 Adversarial Analysis 31

3.5.1 Evasion Attack 33

3.5.2 Poisoning Attack 43

3.6 Discussion 45

CHAPTER Page

3.7 Related Work 46

3.8 Conclusion 48

4 AN ANALYSIS OF CONCESSION-ABUSE-AS-A-SERVICE 49

4.1 Introduction 49

4.2 Overview 52

4.3 Anatomy of Concession-Abuse-as-a-Service 54

4.3.1 Scam Actors 55

4.3.2 Preparation 56

4.3.3 Execution 57

4.3.4 Monetization 58

4.4 Analysis of CAaaS Features and Scale 60

4.4.1 Analysis Approach 60

4.4.2 Targeted Merchants and Goods 62

4.4.3 CAaaS Service Fee 65

4.4.4 Geolocation of Scammers and Merchants 66

4.4.5 Scam Scale 67

4.4.6 From Novice to Seasoned Scammer 69

4.4.7 Financial Loss 72

4.4.8 Scammer Overlap 75

4.5 The Success and Failure of CAaaS 77

4.5.1 Preparing for the Scam 77

4.5.2 Tricks During Scam Execution 78

4.5.3 Monetization Tactics 82

4.5.4 Failure Causes 82

CHAPTER Page

4.6 CAaaS Mitigation 84

4.6.1 Analysis Approach 84

4.6.2 Account Abuse Detection Principles 86

4.6.3 CSR Operational Protocol 87

4.6.4 Merchant Operation Protocol 90

4.6.5 Survey of Customers' Attitudes to Proposed Defenses 92

4.7 Limitations 94

4.8 Related Work 95

4.9 Conclusion 96

5 PLANNED: AN ANALYSIS OF THE PHISHING REPORTING ECOSYSTEM 98

5.1 Introduction 98

6 COMPLETED AND PLANNED WORK 100

REFERENCES 103

APPENDIX

A WORK II: SERVICE FORM IN PREPARATION STAGE 113

B WORK II: SCAM TUTORIALS 114

C WORK II: SURVEY QUESTIONS AND RESULTS 115

D WORK II: SERVICE LIST OF A SCAM SERVICE PROVIDER 119

LIST OF TABLES

Table Page

3.1 Content and purpose categories of public and private threads. 19

3.2 Number of recipients in different public and private interaction categories. 22

3.3 Poster and replier statistics based on their public thread contents and interaction purposes. 23

3.4 Number of recipient-posters and recipient-repliers in different public and private interaction categories. 25

3.5 Features used in the detector. 27

3.6 Classifier configurations. 28

3.7 Detection Performance in the Underground Forum. 29

3.8 Detection performance of user pairs containing top $n\%$ of publicly active users. 33

3.9 Detection performance with unchangeable features. 42

4.1 Popularity statistics for the forums I analyzed. 53

4.2 Quotes from criminals involved in CAaaS. 56

4.3 CAaaS topic statistics for the forums. 62

4.4 Partial concession abuse service list for a top service provider. 64

4.5 Discussions in telegram group. 74

4.6 The number of CAaaS scammers participating in other illicit activities (total CA actors: 49,720). 76

4.7 Overview of participants' attitudes toward my security protocols. 85

A.1 Service form questions. 113

B.1 Tutorials for Concession Abuse. 114

C.1 Survey questions. 116

C.2 Demographics of participants. 117

Table Page

C.3 General security experience and attitude. 117

C.4 Participants' concerns about security approaches. 118

C.5 Participants' attitudes toward security approaches. 118

D.1 A Concession Abuse service list. 119

LIST OF FIGURES

Figure Page

3.1 A public post in which a vendor is selling cracked accounts. 14

3.2 Private messages exchanged between the same vendor in Figure 3.1 and a buyer. 15

3.3 ROC curves of detection of overall user pairs. 30

3.4 The growth of private interactions over the fraction of top active users. 31

3.5 ROC curves of detection of user pairs that contain top 5% of publicly active users. 32

3.6 Detector performance on the single-user non-strategic attack. 35

3.7 Detector performance on different two-user non-strategic attack methods. 37

3.8 Detector performance on the single-user strategic attack. 39

3.9 Detector performance on the two-user strategic attack. 41

3.10 ROC curves of detection by using unchangeable features. 42

3.11 Detector performance on the random poisoning attack. 44

3.12 Detector performance on the normal-user-based poisoning attack. 45

4.1 The steps and actors in CAaaS. 55

4.2 Top ten targeted merchants advertised by CAaaS providers. 63

4.3 Geographical distribution of concession abuse scammers from the NULLED forum. 66

4.4 Trends in new scammer registrations and total forum members, monthly from 2006 to 2018. 67

4.5 Trends in newly created scam threads and total threads, monthly from 2006 to 2018. 68

4.6 Support received from experienced scammers. 70

Figure Page

4.7 The growth of scammers over time while learning. 71

4.8 Timeline of the activities of a scammer who eventually switched roles and became a service provider. 72

4.9 Member activities over the time in a telegram group of a scam provider. 73

6.1 The timeline of my Ph.D. journey. 100

Chapter 1

INTRODUCTION

Approximately 4.80 billion people (nearly 61% of the global population) are active Internet users worldwide in July 2021 [1]. A significant amount of their time is spent on Internet related to searching, working, learning, communicating, shopping, and entertainment. Despite the fact that the Internet offers enormous conveniences and opportunities to people around the world, it is also a platform for criminals to launch illicit attacks (e.g., stealing private data and credentials from people). Hence, cybercrime is growing and caused a loss of $600 billion in 2017 compared to $445 billion in 2014 [58]. As per the annual report of the FBI, they received 791,790 complaints with more than $4.1 billion reported losses, indicating a 69% increase in total complaints from 2019 [31].

Analysis of cybercrimes indicates that these attacks are conducted not only by sophisticated criminals but also by a large number of unsophisticated attackers due to the availability of criminal services and illicit products in underground economies. As an example, between 2012 and 2014, 4,000 people purchased Distributed Denial-of-service (DDoS) services from one service provider and conducted 603,499 attacks on more than 220,000 targets, including companies, schools, colleges, and government departments [86]. Moreover, ransomware toolkits and Ransomware-as-a-Service were widely traded in underground forums, and upgradeable variants of the ransomware, *WannaCry*, that infected more than 230,000 computers across 150 countries within one day [57] can be purchased in underground forums for only $50 [36]. Therefore, it is imperative to analyze and understand the underground forums and markets, which have been the new rendezvous sites for cybercriminals, to detect and prevent

cybercrime proactively.

In light of the important role that underground forums play in the cybercrime ecosystem, a considerable amount of research effort has been invested in studying the organizational structures of the users [[5, 114, 117]], their social dynamics, such as how users gain and lose trust [4, 71], the goods and services sold [25, 29, 104, 115], and how such sites assist specific forms of cybercrimes [40, 96]. These studies have significantly advanced our understandings of the underground economies and have guided law enforcement agencies and affected businesses in how to respond to cybercrimes [104].

However, the research community has largely ignored the nature of underground forums while concentrating on publicly available information. In underground communities, people publicly share a very limited amount of information, maybe even fabricate information, to avoid being identified, and resort to private interactions for follow-up and detailed discussions. Therefore, analyzing users' private interactions can reveal a wealth of information, such as the illicit flow of funds, identifying the criminals responsible, etc., while our community is unaware of the sort of information we can glean from users' private interactions.

To this end, I will present the analysis of private interactions in underground forums in Chapter 3, in which I investigate private interactions in the underground forum in terms of different types of discussed content and purpose to compare how users' private interactions are different from their public interactions. Also, I illustrate the public activities of private message recipients to understand how they behave differently from general users. Moreover, I disclose the relationship between public and private interactions of private message recipients. Finally, I design machine learning (ML) models that take the characteristics of underground forums into account to detect private interactions between users. The results show that our models are effective in detecting private interactions and can withstand evasion and poisoning

attacks.

Additionally, criminals e-commercialize traditional cyber attacks to maximize profits and minimize risks, allowing anyone to launch sophisticated cyber attacks by providing cybercrime-as-a-service [94], such as providing DDoS services [49] and malware distributing services (e.g., pay-per-install services [19]). Since the underground forums have evolved into criminal freelance markets through which criminals exchange skills, trade illicit software and goods, and offer various cybercrime services, criminals can develop new sophisticated cybercrimes by utilizing the underground resources. However, current research rarely examines and explores how criminals interact with each other to create new cybercrime models, but instead focuses on measuring e-commercialized traditional attacks [50].

Toward this end, I will discuss an emerging sophisticated scam service operating in underground forums in Chapter 4, which takes advantage of online retailers' return policies (through social engineering) and the exploitation of loopholes in company protocols. Additionally, I will disclose how the criminals coordinate a diverse range of parties to facilitate the scam and the operations of the scam service. Moreover, I characterize the techniques and tactics used by criminals to effectively defraud merchants, as well as failure cases and limitations of such techniques. Furthermore, I identify attributes that can be used to fingerprint the criminals and CAaaS, propose mitigation approaches suitable for merchants, and evaluate these approaches.

Additionally, in clearnet, the phishing attack has become one of the most prevalent cyber attcks [107, 113] that exploits human-centric vulnerabilities [111] to lure victims into disclosing their sensitive information (e.g., personal identity information, account credentials) by leveraging social engineering [14]. According to the FBI, the phishing attack is a prominent type of cybercrime because of the most significant number of complaints (241,342 complaints, an increase of 110.4% from 2019) received in 2020

compared with other crime types [31].

To empower users' ability to defend against phishing attacks, in addition to proposing and developing various anti-phishing technical solutions [3, 62, 101] to combat the cat-and-mouse game with the phishers, researchers have been investing significant effort in educating the weakest link in phishing, humans, which has been identified as an effective strategy to defend against social engineering attacks [2]

Although phishing awareness training is proven to decrease the rate of clicking phishing emails [21], the rate of reporting phishing attacks is unexpectedly low: 93% of employees did not report the phishing emails in the phishing test [105], and 95% of phishing emails were not reported even within one week after the phishing awareness training [106]. Considering that reporting phishing attacks also can facilitate more phishing sites getting blacklisted earlier and can deter further victimization by the same phishing sites [77, 80], it is imperative to understand the reasons behind the low rate of reporting phishing attacks, which has been largely overlooked. Furthermore, I notice that another two forms of phishing attacks, smishing and vishing, in which phishing messages are delivered through short message service (SMS) and voice, are becoming more common nowadays because 84% and 83% of organizations faced smishing and vishing attacks in 2019, respectivelly [83]. However, little research has been conducted to study the challenges of dealing with these emerging phishing attacks within the existing phishing reporting ecosystem.

I, therefore, intend to conduct a thorough analysis of the phishing reporting ecosystem during the following stage of my Ph.D. journey to identify the critical challenges people face and concerns they have when reporting smishing, vishing, and phishing email attacks. To this end, I plan to conduct three experiments to investigate the ecosystem from three perspectives to gain a better understanding of: (1) what the reporting ecosystem offers individuals seeking to report phishing attacks, (2) what the

actual experience is in preparing to report a phishing attack, and (3) what happens to the phishing websites and reporters after reporting.

Chapter 2

BACKGROUND

2.1 Underground forums.

Underground forums and marketplaces are used as rendezvous locations for cybercriminals who want to exchange information and trade illicit products and services [94, 115]. To this end, a considerable amount of research effort has been invested in understanding the underground economies, which primarily come from two perspectives: 1) the users and 2) the businesses.

Users in Underground Forums. Researchers studied users' interactions and characteristics to disclose valuable intelligence in underground forums [5, 71, 114, 115]. Motoyama et al. analyzed six underground forums to characterize users' social networks in underground forums and demonstrate the impact of their reputations on the interactions of users in underground forums [71]. Zhao et al. analyzed social dynamics relevant to net-centric attacks to discover adversarial evidence [114].

Moreover, researchers applied analysis methods in Online Social Networks (OSN) to analyze the organizational structure of underground forums. Pastrana et al. characterized key actors and groups in underground forums and developed tools to detect and predict such users in underground forums [79]. Benjamin et al. proposed methods to identify key actors by studying hackers' reputation and discussed the relationship between users' activities and their reputations [11].

Additionally, researchers characterized users in underground forums, such as identifying anonymous authors of texts in underground forums by analyzing users' writ-

ing styles [5]. Kigerl profiled users based on topics of their posts in underground forums [52].

In spite of the fact that Radianti et al. pointed out that users in underground forums and marketplaces prefer to discuss details in private communication channels [85], private interactions in the underground society have been largely overlooked.

Business in Underground Forums. The business conducted in underground forums has attracted considerable attention as a result of the significant financial gains and the wide variety of illicit products offered. Thomas et al. Investigated web services that create and trade fraudulent accounts by cybercriminals in underground markets [104]. Franklin et al. analyzed the marketplaces in underground forums and estimated the value of goods traded in the markets [35]. Moreover, researchers presented an analysis of stolen credentials traded in the underground forums and studied the risks to victims [93, 102]. Samtani et al. analyzed what hackers share in underground forums and the characteristics of these shared assets by using classifiers and topic modeling techniques [88].

Additionally, various criminal services are also available in underground forums, such as the reshipping service that helps cybercriminals monetize stolen credit cards and contributes $1.8 billion to overall reshipping scam revenue [38]. Users can also buy underground services to facilitate their real-world business, such as buying account followers [6] or fake reviews [110]. Additionally, Caballero et al. analyzed the operations and impacts of a malware distribution service, pay-per-install (PPI) service, in undergrounds [19]. Stone-Gross et al. [96] explored the underground economy of large-scale Spam operations through analyzing a private forum, Spamdot.biz.

Moreover, the products in the business enable anyone to launch sophisticated cyber attacks. Researchers have analyzed phishing kits and services in underground

forums [75, 76, 94, 113] to reveal phishing service costs, operational steps, and phishing attacks. Karami et al. analyzed DDoS-as-Service in underground forums to show the internal operations, usage patterns, and attack infrastructure [49, 50].

2.2 Social engineering.

Social engineering is to manipulate victims into sharing confidential information or performing specific actions through influence and persuasion [53]. Compared with cyber attacks on systems, it is hard to protect from social engineering attacks because people are easy to be influenced and not good at identifying deceptions [84].

To protect the weakest link, humans [2], from social engineering attacks, Atkins et al., and Ferreira et al. studied the persuasion techniques used in social engineering [8, 33]. By analyzing 74 scenarios, Bullée et al. disclosed which persuasion principles are most effective for social engineering attacks [17]. Irani et al. studied reverse social engineering attacks that deceived people into visiting malicious websites by abusing social networks, without the need to engage directly with victims [44]. Researchers also conducted studies of web-based social engineering attacks that trick users into downloading malicious software [48, 72].

2.3 Phishing.

The phishing attack is one of the most prevalent cyber attacks [107, 113] that leverages social engineering [53, 76] to lure victims into disclosing their sensitive information like entering credit card numbers on fake websites, opening malicious attachments in phishing emails, and replying to phishing messages [14, 41]. Furthermore, the phishing attack is a prominent cybercrime type discovered by the FBI because of the largest number of complaints (241,342 complaints, an increase of 110.4% from 2019) received in 2020 compared with other crime types [31].

According to the different delivery methods of phishing messages, there are generally three major forms of phishing attacks, which are phishing email, smishing, and vishing attacks [111].

Phishing Email Attack. This is the most common form of phishing attacks that scammers send phishing messages through email to victims [107]. By taking advantage of various social engineering tactics, such as "urgency" [41], scammers deceive victims into logging in to a well-crafted fake webpage of a popular website, such as Facebook, to steal their account credentials. Moreover, phishing emails may request victims to reply with their personal information, such as Social Security Number (SSN), to claim a gift card or resolve a problem. Additionally, another common approach is to lure victims into clicking malicious attachments to download malware and infect their computers [107].

Smishing Attack. Smishing is another form of phishing attack whose phishing messages are delivered through short message service (SMS) on mobile phones [111] Smishing attacks deceive people into performing similar actions to phishing email attacks by visiting a fake website, replying with sensitive information, and downloading a malicious application. Due to the small size of the mobile device, it is difficult for people to check whether a webpage is legitimate from URLs through the mobile version webpage display [92], especially 70% of people do not know smishing attacks [83]. Therefore, this form of phishing attack has become more popular, and 84% of global organizations suffered smishing attacks in 2019 [83].

Vishing Attack. By leveraging Voice over Internet Protocol (VoIP), scammers deliver phishing messages through voice to socially engineer victims into disclosing their sensitive information, such as SSN and credit card numbers [111].

Rather than directing victims to a fake webpage, scammers frequently provide pretext that makes victims feel comfortable and obliged to divulge their confidential information [47, 91]. A typical example is that scammers spoof their Caller ID to appear to be originating from a bank and contact victims for their unusual account activities. In the meantime, victims need to verify their sensitive information, such as SSN and account number, first before discussing and resolving the issues [91].

Additionally, according to a report from Proofpoint, people have a low awareness rate of vishing attacks (25%), and 83% of global organizations faced this form of phishing attacks in 2019 [83].

Chapter 3

PRIVATE INTERACTIONS IN UNDERGROUND FORUMS

3.1 Introduction

Underground forums and marketplaces have been the rendezvous sites for cybercriminals of all kinds to exchange information and sell illegal products and services. Given the important roles these sites play in the cybercrime ecosystem, a considerable amount of research effort has been invested in studying the organizational structures of their users [5, 114, 117], their social dynamics, such as how users gain and lose trust [4, 71], the goods and services sold [25, 29, 104, 115], and how such sites assist specific forms of cybercrimes [40, 96]. These studies have significantly advanced our understandings of the underground economies and have guided law enforcement agencies and affected businesses in how to respond cybercrimes [104].

Nevertheless, the research community has only been looking at the tip of the iceberg of underground forums and marketplaces in that *We have only investigated posts and threads that are publicly available to all registered users or even anyone on Internet*. However, due to the nature of underground forums and marketplaces, their users tend to share a very small amount of information in public interactions and resort to private interactions for follow-up conversations. Hence, analyzing private interactions can disclose a wealth of information, such as the illicit financial flow, narrowing down the suspects who commit the crime, etc., while our community is not even aware of what sort of information we could glean from private messages.

In this work, I investigate private interactions in underground forums by analyzing the leaked dataset of Nulled.io. Nulled.io is a popular underground forum where users

discuss hacking, exploits, monetization methods, etc. The released forum dataset includes public and private messages from Jan 14, 2015 to May 6, 2016, which makes it an excellent sample for comparing the similarities and differences between public and private interactions.

To study the private messages of Nulled.io, I develop a semi-automatic approach to categorize private messages into content and purpose categories, to compare how private messages are different from public posts. Moreover, I present the artifacts discovered via my analysis of private messages, such as the payment methods, contact information, etc. My analyses show that the content and purpose distributions in private messages *are different from* their public counterparts and that there is much more sensitive information, such as the users' contact information and Bitcoin addresses in private messages than in public posts. In the meantime, private exchanged information is not always undisclosed in public.

In addition, I analyze who are more likely to be contacted in private interactions by studying public interactions of `recipients`, users who receive the initial message in a private thread, to understand how they behave differently from other users. I compare public and private interactions of `recipients` to study the relationships between their public and private activities. Also, I analyze different types of public posting methods, such as creating a post and replying to a post, and study which type of posting method is more likely to attract private interactions.

I also design several ML-based approaches to *detect private interactions* in underground forums based solely on public information. In essence, my approach uses publicly available information to uncover hidden connections between users. The evaluation results indicate that my approach effectively detects private interactions with 94% accuracy. Additionally, I perform adversarial analysis to evaluate the robustness of the detector to different types of attacks. My analyses shows that the

detection has a considerable effective robustness to multiple types of evasion attacks. Also, the evaluations indicate that poisoning attacks performed by the administrators of underground forums cannot prevent the private interactions from the detector effectively.

The contributions of this work are summarized as follows:

- I analyze private messages in the underground forum in terms of different types of discussed content and purpose to compare how private messages are different from public posts. Also, I manually analyze the most popular artifacts in private messages.
- I study the public activities of private message recipients to understand how they behave differently from general users. Moreover, I analyze the relationship between public and private interactions of private message recipients.
- By considering the characteristics of underground forums and leveraging findings from previous studies and carefully selected features, the ML-based detectors can effectively detect private interactions from public information.
- I present adversarial analyses against the detectors to evaluate their robustness.

```
Vendor: Selling HideMyAss VPN premium accounts. Type of accounts: monthly
    membership with auto renew. Price is $5 BTC. Do not change the password/email
    of the account. I am not responsible if you get banned for breaking the TOS of
     HMA, make sure to read it first. All sales are final.
```

Figure 3.1: A public post in which a vendor is selling cracked accounts.

3.2 Motivating Example and Data Overview

There are many studies on analyzing user interactions in public social networks [10, 18, 56, 64], most of which focus on public interactions that can be accessed by anyone, such as likes, reposts, shares, replies or tagging pictures. Similar public interactions are also utilized to analyze the social dynamics of underground forum users [68, 114, 117]. However, private interactions on underground forums have been largely overlooked. In this section, I present a motivating example that sheds light on what may be discovered in private messages. I also discuss the dataset that is used in this work and how I preprocess the raw data.

3.2.1 Motivating Example

As a motivating example, as shown in Figure 3.1, a vendor of Nulled.io tries to sell cracked accounts in a public post. However, the public post does not include any detailed information that is needed to finish a transaction, such as the payment or delivery methods. In contrast, corresponding private messages from the same vendor is shown in Figure 3.2, and these message comprise much more detailed information. To anonymize users' identities, I use "Buyer" and "Vendor" to represent their user IDs in the forum. I also use "BTCADDRESS," "USERNAME," and "PASSWORD" to represent the vendor's Bitcoin address and the cracked account login credentials.

```
Buyer: I want to buy one hide my ass account with bitcoin can I? Thanks
Vendor: Sure, price is $5 BTC. Ready to send BTC over? BTW i can give you 3
    accounts for $12 BTC, that is a current deal. :)
Buyer: No I want only one thanks. Yes, I'm ready please sen me your btc
    address.
Vendor: Sure, send btc to: <BTCADDRESS>
Buyer: Sent.
Vendor: <USERNAME>:<PASSWORD>. Enjoy :)
Vendor: BTW can you leave a vouch in my sales thread? Thanks in advance. :)
Buyer: Thank you too. Feedback sent :)
```

Figure 3.2: Private messages exchanged between the same vendor in Figure 3.1 and a buyer.

The private messages in Figure 3.2 show that a user contacts the vendor to buy a cracked account of *HideMyAss*, which is a VPN service provider and its original service price is $11.99/month. Besides the advertised price ($5/account), the vendor offers a deal ($12 for 3 accounts) to the buyer as well. Also, the vendor's Bitcoin address is disclosed in the private messages. As the vendor asks the buyer to vouch for the transaction on the public post, I find the buyer leaves *"Bought from him, all was great :) Account is working"* in the original public thread. Therefore, private interactions can reveal much useful information undisclosed in public posts. In the meantime, as shown in Figure 3.2, private interactions is a crucial step to fulfill the trading in the underground forums. Hence, detecting private interaction can help disclose hidden connections between users, and potentially reveal the goods trading flow.

3.2.2 Data Overview and Preprocessing

In this paper, I use a dataset from Nulled.io, a very popular hacker forum where users mainly discuss hacking, exploits, and monetization methods. I do not claim this forum represents all underground forums, but it can provide insights into user activities in underground forums. I obtained this dataset from an unknown third party who made it publicly available. Ethically, I do not attempt to identify users in my analyses, and use expressive words to represent corresponding sensitive information, such as "Vendor" and "BTCADDRESS" shown in Figure 3.1 and Figure 3.2 to represent seller's user ID and Bitcoin address. Moreover, using leaked and publicly available datasets is an acceptable practice in the study of the underground ecosystem [5, 71].

This dataset has a wealth of information. In particular, it has 599,085 member profiles, including email address, the date of joining the forum, IP address, membership, etc. It has 3,495,596 public posts from Jan 14, 2015, to May 6, 2016, which belong to 121,499 different public post threads. There are also 673,157 user login logs, which contain access time, user ID, and location.

In addition, this dataset has 800,593 private messages, which belong to 404,355 private message threads. These messages have contents, sending time, sender ID, receiver ID, etc. My preliminary analysis shows that 70.9% of these threads are started by the system or moderators to welcome a new user or to send warning notifications. I exclude those threads from further analysis. As a result, there are 512,227 private messages that belong to 117,708 private message threads and 43,518 user pairs who had private interactions.

To preprocess text data, I retrieved the raw data of public and private messages directly from the forum's database. I used an HTML parser (Beautiful Soup) to remove all these tags. Next, I used a sentence splitter from NLTK (Natural Language

Toolkit) to divide the text content into sentences. I also used lemmatizers in NLTK to reduce inflectional forms to a common base form. For example, after this step, "took," "taken," and "takes" will be changed to "take". Moreoer, I removed all the stop words in the NLTK stop word list from the raw data and punctuation marks from the messages.

3.3 Private and Public Message Analysis

In this section, I study the private and public messages from the dumped database for the website Nulled.io. My goals are to understand: (1) *what* users discuss in private messages, (2) *why* users use private messages, and (3) *how* private message discussions are different from public interactions.

3.3.1 Content and Purpose

I first investigate the difference between public and private threads in terms of the content and purpose of the communication. Content is the topic the thread is discussing, and purpose is the high-level goal of the thread.

The challenge inherent in answering this question is to recognize the content and purpose for a large number of messages from the database. To solve this challenge, I apply an approach for text topic classification [35, 73]. Specifically, I first explore contents and purposes by manually labeling a subset of the data, and then use a machine learning model to label messages with contents and purposes. To create the manually labeled data, I randomly select 1,000 public and 1,000 private threads from the dump dataset. I then use support vector machines (SVM) for training. To preserve ordering information, I extract 1-gram, 2-gram, and 3-gram sequences from each thread. I ignore all sequences that appeared in more than 80% of the threads to remove the most frequent ones (as these are used in so many disparate

threads and would provide very limited information on the content and purpose). As a result, each thread is represented as a 66,959-dimensional term frequency-inverse document frequency feature vector. I randomly select 20% of the labeled threads and utilized grid search and five-fold cross-validation to tune the SVM model parameters. Finally, I trained separate classifiers for the purpose and content categories. With the optimized parameters, my SVM classifiers have around 0.84 F1 scores on the labeled dataset. In the end, I use the SVM classifiers with tuned parameters to classify all public and private threads.

The content and purposes are shown in Table 3.1. If I cannot label a thread based on the text content, such as a thread with the untranslatable language content, then the interaction purpose and content of this thread will be labeled as *N/A*, I categorize contents to four general classes: `monetization` (e.g., introducing approaches to making money or transferring the money), `stolen credential` (e.g., stolen account credentials, cracked account credentials, or compromised data), `hacking-related` (e.g., hacking services, hacking technique support, and hacking tutorials) and `other`. In the meantime, I also categorize purposes to the following four general classes: `trading` (e.g., selling and buying), `sharing` (e.g., giving away materials or things for free), `supporting` (e.g., seeking or providing help) and `other`.

Table 3.1 shows the content and purpose statistics in public and private threads. In terms of content, I find hacking, miscellany, and monetization are mentioned more frequently in public than in private, whereas stolen credential is mentioned more frequently in private than in public. This is likely because stolen credential is more valuable, and people would prefer to keep it private. However, monetization is also valuable, yet `monetization` is discussed less in private than in public. My manual analysis indicates one possible reason of such change is that many of the posters of `monetization` threads request users to contact them through third-party messengers,

Table 3.1: Content and purpose categories of public and private threads.

	Labeled as	Refined Categories	Public Threads	Private Threads
Content	Bitcoin, Card, Amazon, Money	Monetization	1.7%	0.6%
	Password, Data, Account	Stolen Credential	21.7%	34.6%
	Program, IP, App, Rat, Experience, Hacking, SEO, VPN, Service, Script, Configure Setting, Bot, Website, Proxy, Botnet, Server, Cracking Guide	Hacking-related	48.9%	37.4%
	Video, Story, Tip, Photo, Game, Self Introduction, Device, Rule, Movie, People, Ban, Threads, N/A	Other	27.8%	27.3%
Purpose	Buying, Selling	Trading	13.4%	33.2%
	Sharing	Sharing	48.3%	2.5%
	Help-seeking, Help-offering	Supporting	27.7%	49.5%
	Greeting, Arguing, N/A	Other	10.6%	15.2%

such as Skype, or directly access their shopping websites.

In terms of purpose, I notice that more public threads aim to share information while more private threads aim to trade, support, greet, or argue, which is aligned with previous findings [85]. Moreover, I find that public sharing is associated with private trading: 96.6% of users who engage in `trading` private threads also have `sharing` public interaction purposes. I believe that this is because a user who publicly shares goods implies that they have more goods, and buyers tend to privately contact the original poster for questions and trading. In a sense, this is a form of advertising. For example, one user often shares many login credentials of cracked game accounts in his/her public posts. Many users privately contact the sharer for trading, such as *"Hey i'd like to buy a lvl 30, i hope it would be possible for me to change the email*

as well."

3.3.2 Artifacts

Based on the content labeling model in Section 3.3.1, I analyze the popular artifacts in public and private threads. I study login credentials, proxies, contact methods (e.g., email and Skype), and payment methods, and I have the following observations:

Most users constantly keep their personal contacts either in public or in private. For example, among all the email contacts found in private threads, only 1.9% of the email contacts appear in both public and private threads. Also, users tend to keep their Skype ID secret until the end of the trading. I discover that only 41.1% of Skype-mentioned private threads include Skype IDs.The analysis shows that many users who engage in Skype-mentioned private threads cannot reach initial deals before exchanging Skype IDs or they prefer to use the built-in private messaging function of the forum.

In addition, I notice that privately exchanged goods are also disclosed in public. For example, only 64.2% and 40.2% of privately exchanged credentials and proxies, which are most frequently exchanged in public, are never discussed in public.

Forum administrators also host multiple payment accounts. Those accounts are used to collect the administrative fee such as account upgrading and tested products purchasing. I found 7 payment accounts, and 6 of them are found from private threads. This implies that one should establish private interaction with the administrators to investigate the financial status of the underground forum.

Previous research has conducted per-user analysis, based on the fact that duplicated users are typically not allowed in the underground forum. However, I observe that 37 out of 1,165 PayPal accounts are used by multiple users, which implies that duplicated users exist in the underground forum. My manual analysis indicates that

these forum accounts likely to belong to the same person, because these users are performing the same business, clearly leaving the same private contact information, such as Skype IDs. Also, I notice that these users, who have multiple accounts linked by the same PayPal account, have used precautions to avoid being identified by the forum's Duplicated-Account detection system: they use different IP addresses when logging into their different user accounts. They also take care to use email addresses and usernames that are very different from their other accounts. Additionally, I notice that nearly 86% of such multiple-linked accounts are identified from the private threads, therefore demonstrating the importance of private messages to understanding an underground marketplace.

3.3.3 Private Message Recipients Behavior

A *private message recipient* is a user that is initially contacted in a private thread. As private messages can contain more security sensitive contents and purposes, studying private message recipients will help us understand how private interactions are initiated. In this subsection, I study two questions:

- What is the difference in the public activities of private message recipients and other users? Specifically, what is the difference in public security messages, posts, and replies, and private security posts and replies?
- How do private message recipients behave in public as compared to in private?

To answer these questions, I take advantage of messages with content and purpose labels (§ 3.3.1). I divide the messages into two groups by whether its author is a private message recipient or not. For each group, I calculate the proportion of users involved in the messages with different content and different purposes. In the dataset, there are 43,518 user pairs who have private interactions, and 16,997 users are `recipients`. The statistic results of this analysis are shown in Table 3.2.

Table 3.2: Number of recipients in different public and private interaction categories.

		# Users in Public	# Recipients in Public	# Recipients in Private
Content	Monetization (a)	25,448 (4.2%)	6,524 (38.4%)	26 (0.2%)
	Stolen Credential (b)	93,645 (15.6%)	13,571 (79.8%)	6,817 (40.1%)
	Hacking-related (c)	279,148 (46.6%)	16,481 (97.0%)	7,221 (42.5%)
	a ∧ b	18,679 (3.1%)	6,222 (36.6%)	22 (0.1%)
	a ∧ c	24,509 (4.1%)	6,498 (38.2%)	23 (0.1%)
	b ∧ c	81,824 (13.7%)	13,387(78.8%)	5,096 (30.0%)
	a ∧ b ∧ c	18,463 (3.1%)	6,203 (36.5%)	21 (0.1%)
	Total	291,692	16,672	8,944
Purpose	Trading (d)	32,988 (5.5%)	9,823 (57.8%)	6,983 (41.1%)
	Sharing (e)	288,403 (48.1%)	16,501 (97.1%)	541 (3.2%)
	Supporting (f)	92,091 (15.4%)	14,224 (83.7%)	8,151 (48.0%)
	d ∧ e	31,867 (5.3%)	9,697 (57.1%)	471 (2.8%)
	d ∧ f	24,021 (4.0%)	8,946 (52.6%)	5,629 (33.1%)
	e ∧ f	84,121 (14.0%)	14,090 (82.9%)	495 (2.9%)
	d ∧ e ∧ f	23,837 (4.0%)	8,916 (52.5%)	450 (2.6%)
	Total	297,310	16,731	9,530

What is the difference in the public activities of private message recipients and other users? I study the differences in three different aspects: (1) security messages, (2) content-specific and purpose-specific messages, and (3) posts and replies. Security messages are messages with security-related content or purposes. As I stated in Table 3.1, in this work I consider monetization, stolen credential, and hacking as security-related contents, and we consider trading, sharing, and supporting as security-related purposes. Content-specific and purpose-specific messages are labeled with one or multiple content or purposes from the above categories. Posts and replies are two types of messages in public thread. Posts are the messages initializing new threads, while replies are messages posted as follow-ups to existing threads.

- **Security messages.** Column # Recipients in Public and column # Users in

Table 3.3: Poster and replier statistics based on their public thread contents and interaction purposes.

		# Recipient-posters	# Posters	# Recipient-repliers	# Repliers
Content	Monetization (a)	906	1,296	5,618	24,152
	Stolen Credential (b)	5,277	8,491	8,294	85,154
	Hacking-related (c)	8,576	21,172	7,905	257,976
	a ∧ b	631	699	2,888	14,219
	a ∧ c	735	914	2,065	17,087
	b ∧ c	3,739	4,937	4,424	63,666
	a ∧ b ∧ c	551	596	1,339	10,625
Purpose	Trading (d)	4,100	6,093	5,723	26,895
	Sharing (e)	7,741	17,684	8,760	270,719
	Supporting (f)	6,609	16,558	7,615	75,533
	d ∧ e	2,685	3,260	2,895	20,671
	d ∧ f	2,500	3,112	3,035	14,404
	e ∧ f	4,367	6,846	4,763	61,429
	d ∧ e ∧ f	1,935	2,215	1,849	11,696

Public shows the difference of public activities between private message recipients and other users. Private message recipients are more involved in security-related messages. For example, 98.1% of the private message recipients have discussed monetization, stolen credential, or hacking-related topics, whereas 48.6% of the other users have discussed this content. This difference also implies that users involved in more security-related activities will be more likely to be contacted privately.

- **Content-specific and purpose-specific messages.** In particular, I study the difference in posts and replies with specific contents and purposes. Table 3.2 shows the number of unique private message recipients that post/reply a message in a specific topic or purpose, as well as the number of unique recipients that are contacted for the same topic and purpose. For stolen credential, hacking, trading, and supporting, more than 50% of the recipients are contacted with the same content/purpose after posting. However, for monetization and

sharing, few recipients are contacted after posting.

- **Posts and replies.** I compare the total number of the unique authors to that of unique private message recipients, as shown in Table 3.3. Based on these results, I observe that a majority of post authors are also private message recipients. For example, 906 out of 1,296 (69.9%) authors that post monetization messages become recipients. However, many fewer authors are contacted due to their replies. Among 24,152 unique authors that reply to monetization messages, only 5,618 (23.2%) are recipients that are privately contacted by other users. This implies that to attract the other users for private interaction, one should post security messages rather than reply to existing threads.

In addition, I notice from Table 3.3 that there are more `repliers` than `posters` in all the categories. My results show that most of `posters` never reply in his/her created thread, which indicates that `repliers` cannot receive any help from `posters` by replying to their posts. Especially, many initial posts explicitly request users to privately contact the post's creator. Because of this results, I am interested in the reasons for publicly *replying* to posts. My manual analysis indicates one possible reason: `posters` attempts to have a lower *leecher* value. Because many users attempt to take advantage of the underground forum resources without making contributions, the underground forum assigns a *leecher* value to each user, which is used to quantify a user's contribution, where a lower value is better. This value is rated by the system automatically based on various metrics, such as the number of threads a user created, the number of replies a user obtained, etc. If a user has a high *leecher* value, then many of his/her activities will be restricted, such as private message limits, being unable to access particular types of post, etc. To lower the *leecher* value, a user needs his/her posts to have more replies, which imply that more users are interested in his/her posts. Therefore, most of the `posters` use a feature of the forum to hide

Table 3.4: Number of recipient-posters and recipient-repliers in different public and private interaction categories.

		# Recipient-posters in Public	# Recipient-posters in Both Public and Private	# Recipient-repliers in Public	# Recipient-repliers in Both Public and Private
Content	Monetization (a)	906	6	5,618	14
	Stolen Credential (b)	5,277	3,397	8,294	2,900
	Hacking-related (c)	8,576	4,836	7,905	2,301
	a ∧ b	631	5	2,888	5
	a ∧ c	735	6	2,065	4
	b ∧ c	3,739	2,287	4,424	732
	a ∧ b ∧ c	551	5	1,339	3
	Total	10,205	6,807	13,779	4,477
Purpose	Trading (d)	4,100	2,860	5,723	2,557
	Sharing (e)	7,741	405	8,760	133
	Supporting (f)	6,609	4,454	7,615	3,088
	d ∧ e	2,685	269	2,895	43
	d ∧ f	2,500	1,863	3,035	862
	e ∧ f	4,367	313	4,763	47
	d ∧ e ∧ f	1,935	228	1,849	21
	Total	10,833	7,464	13,254	4,847

essential content from the post, and this content is only revealed when other users reply to the post. This also explains why the text content of most of the replies are meaningless, such as *"thx", "ty"*.

How do private message recipients behave in public as compared to in private?

Column # Recipients in Public and column # Recipients in Private show the difference of private message recipients' activities between public messages and private messages. Interestingly, I find that private message recipients discuss *less* about security in private than in public. While 98.5% of the recipients message publicly for trading, sharing, and supporting, only 56.1% of them message privately with similar purposes. Instead, these recipients use private threads for other purposes, such as to argue for reviews in public threads.

Posting is more likely than replying in having similar content or purpose in both

public and private interactions. As shown in Table 3.4, column # Recipient-posterin Public and column # Recipient-posterin Both Public and Private shows the difference of private message `recipient-posters`' activities between public and private messages. In general, 6,807 out of 10,205 (66.7%) `recipient-posters` have similar security related content in both public and private, while it is only 32.5% for `recipient-repliers`.

3.4 Detecting Private Interactions in Underground Forums

In this section, I study the *detection* of private interactions by using two users' publicly available information in underground forums. Because users trade illicit goods or services through private interactions, detection of these private interactions helps to identify illegal activities, trace goods flows, and disclose hidden connections.

3.4.1 Approach Overview

I apply machine learning methods to detect private interactions. I first train machine learning models with constructed user pair instances. Then, I apply the trained models on the testing data and evaluate based on precision, recall, F1 score, and accuracy.

Data Selection. In the `Nulled.io` dataset, there are much more user pairs that do not have private interactions than whose who have. For all of the 599,085 users, only 43,518 user pairs ever have private interactions. I randomly sub-sample user pairs of non-private interaction to avoid the common problems of an imbalanced dataset, such as the bias towards the majority class [22]. Also, I adopt data pruning and cross-field validation in sub-sampling five times to train each classifier. **Feature Extraction.** Based on my observations (described in previous sections), I synthesize three categories of features for the private interaction detection: (1) features from

Table 3.5: Features used in the detector.

	Feature Name	Explanation
Profile Features	Membership [p]	To create a generic approach, I categorize memberships into five classes: (1) Basic membership, such as *Member*; (2) Upgraded membership, such as *Royal*; (3) Limited membership, such as *Banned*; (4) Fee-based membership, such as *VIP*; (5) Staff, such as *Administrator*.
	JoinDate [u]	The time of joining the forum
	LastVisit [u]	The time of the last visit
	Views [u]	The number of views on the user's profile. A user's profile includes user's basic information, reputation values, and activity history.
	Reputation [c,u]	Many forums use multiple types of reputation values to show a user's contributions, honors, and trustworthiness. For example, the Nulled.io forum uses three such values, which are: leecher, like, and reputation, to indicate the user's contributions, honors, and trustworthiness, respectively.
	Banned [p]	A user's status: This is used to show if a user's account is banned in the forum. When a user violates the forum policy, such as creating duplicated accounts and spamming, then the staff members may ban his/her account.
Activity Features	Posts [c]	The number of a user's public posts.
	Threads [c]	The number of public threads a user engages in. This feature shows a user's public activities on different public threads.
	Topics [c]	The number of public threads initiated by a user. This feature indicates how often a user opens new public post topics in an underground forum.
	ThreadViews [u]	The number of views on a user's public threads. This feature indicates the popularity of a user's public threads.
	Subforums [c]	The number of subforums a user is involved in. The underground forum has several subforums for different themes, and the post threads must be published in the corresponding subforum. This feature indicates the number of general themes a user is interested in.
	Friends [c]	The number of users who publicly interact with the user. This feature shows the degree centrality of a user in an underground forum network, which is formed by users' public interactions.
Interaction Features	Interactions [c]	The number of this user pair's public interactions.
	CommonTopics [c]	he number of public threads that have both users' posts. This feature shows how often these two users are interested in the same public post topics.
	CommonSubforums [c]	The number of subforums that both users are involved in. This feature indicates how often these two users are interested in the same general themes in an underground forum.
	CommonFriends [c]	The number of users who publicly interact with both users. This feature reveals the number of direct neighbors shared by these two users in an underground forum interaction network.

[c] Changeable Feature

[p] Partial Changeable Feature

[u] Unchangeable Feature

a user's profile, (2) features from a user's public activities, and (3) features from a user pair, as shown in Table 3.5. The features are from *publicly available and objective information* of a user pair. I choose these features under the following considerations. First, as users try to hide their real identities in the underground forum, they may provide fake or incomplete information. Second, unlike public social networks, underground forums only need users to provide a small amount of profile

Table 3.6: Classifier configurations.

Algorithm	Configurations
NB	alpha = 0.001; fit_prior = "True"
LR	C = 10; solver = "liblinear"
SVM	kernel = "rbf"; C = 100; gamma = 0.01
KNN	n_neighbors = 11; weights = "distance"; algorithm = "ball_tree"
AdaBoost	n_estimators = 250; learning_rate = 1; algorithm = "SAMME.R"
MLP	activation = "logistic"; solver = "adam"; learning_rate = "adaptive"; hidden_layer_sizes = (150,)
RF	n_estimators = 250; max_features = "sqrt"

information, and much of the information is hidden from the public. Also, only a small percentage of users have private interactions, and users typically have a different focus when privately interaction compared to their public interactions.

Training. I use Naive Bayesian (NB), Logistic Regression (LR), Support Vector Machine (SVM), K-Nearest Neighbors (KNN), AdaBoost, Multi-Layer Perceptron (MLP), and Random Forest (RF) to detect private interactions in the underground forum. Table 3.6 shows the best performance configurations of each classifier.

3.4.2 Testing Results

Detection Performance of Private Interactions of Overall Users.

I used five-fold cross-validation in my experiments, and all features were normalized. Table 3.7 shows the detection performance of each classifier. The precision is the fraction of correctly identified private interaction instances among all of the detected private interaction instances. The recall indicates the percentage of private interaction instances are correctly identified. The F1 score is used to measure the overall performance while considering both the precision and recall.

Table 3.7: Detection Performance in the Underground Forum.

Algorithm	Precision	Recall	F1 Score	Accuracy
NB	0.85	0.80	0.82	0.82
LR	0.85	0.92	0.88	0.88
SVM	0.90	0.93	0.92	0.91
KNN	0.87	0.94	0.90	0.89
AdaBoost	0.91	0.94	**0.93**	0.92
MLP	**0.93**	0.94	**0.93**	0.93
RF	0.92	**0.96**	**0.93**	**0.94**

As shown in Table 3.7, the algorithms can effectively detect private interactions. Most of the algorithms can achieve higher than 0.85 in precision and 0.92 in the recall. In particular, ensemble algorithms, AdaBoost, and RF, and the neural network algorithm, MLP, have the highest F1 score. In the meantime, MLP has the best performance on precision. Additionally, RF outperforms other algorithms on overall accuracy and recall. As AdaBoost, MLP, and RF have at least one of the best measurement performances, I focus on these three algorithms in the rest of the chapter.

Figure 3.3 depicts the ROC curves of detecting private interactions by using the three algorithms. In general, all of the algorithms have a high true positive rate (TPR) and low false positive rate (FPR). In particular, RF and MLP outperform Adaboost. Additionally, I observe that, with 10% FPR, MLP can achieve more than 95.5% TPR and RF has less than 4% false negative rate (FNR).

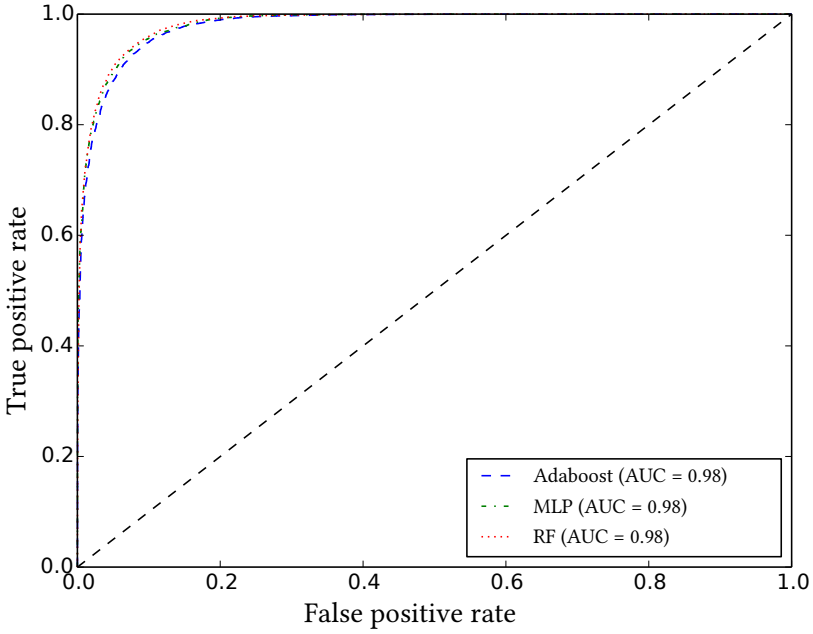


Figure 3.3: ROC curves of detection of overall user pairs.

Detection Performance of Private Interactions of Publicly Active Users.

As shown in Figure 3.4, the top 10% of privately active users engage in 80% of the total private interactions, and users who are in the top 10% publicly active engage in nearly 90% of total private interactions. To detect private interactions of top publicly active users, I constructed multiple experimental subsets from the dataset containing private interaction user pairs that consisted of users who were top n of publicly active (where n is set to 5%, 10%, and 15%). I used the same number of user pairs of non-private interactions and user pairs with private interactions to form balanced subsets.

Table 3.8 shows the detection performance results using AdaBoost, MLP, and RF. "PI Coverage" in Table 3.8 indicates the percentage of private interactions involving the users who are in the top n% of publicly active users. Note that 79.2% of private

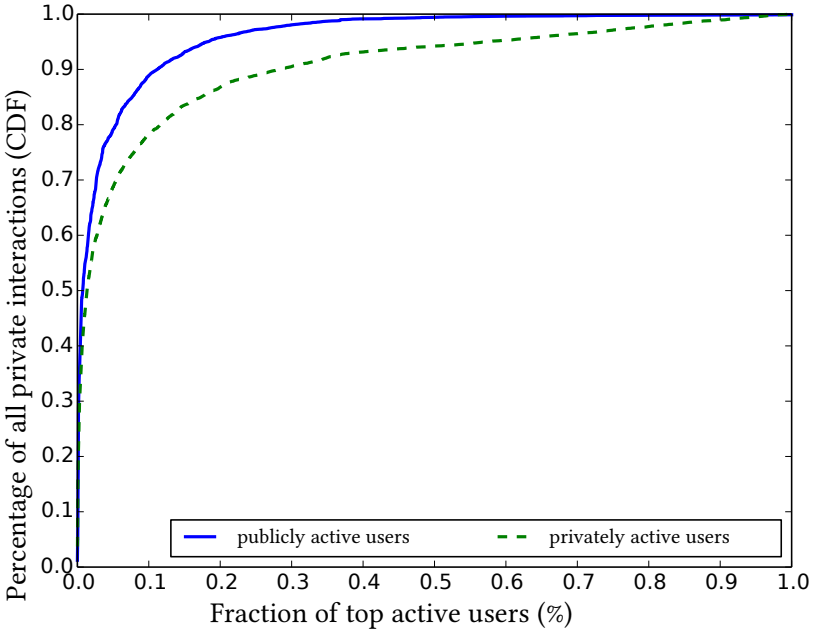


Figure 3.4: The growth of private interactions over the fraction of top active users.

interactions attribute to the top 5% of publicly active users. As clearly shown in Table 3.8, the classifiers have better performance in detecting private interactions for the top n% of publicly active users.

Figure 3.5 shows the ROC curves of detecting private interactions of users pairs that contain the top 5% of publicly active users. Different from overall detection performance, Adaboost has a better performance than MLP. Moreover, the algorithms have a higher TPR in Figure 3.5 than in Figure 3.3 at the same FPR.

3.5 Adversarial Analysis

In Section 3.4, I show that my approach can effectively detect private interactions in the underground forum. In this section, I perform adversarial attacks analysis to evaluate the robustness of my detection technique.

Because many users prefer to discuss and exchange illicit detailed information

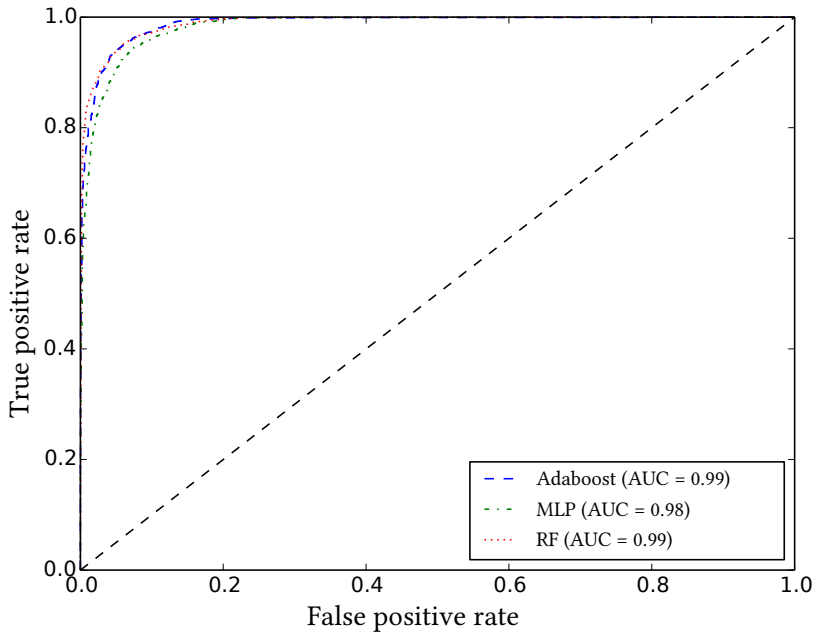


Figure 3.5: ROC curves of detection of user pairs that contain top 5% of publicly active users.

in private, in order to escape detections they may *intentionally change their public behaviors* in the underground forums. Also, to maintain the underground forums normal operations, to protect and attract users, administrators of underground forums could perform actions to prevent their users' private interactions from being detected. Therefore, it is crucial to evaluate the robustness of my detector in different adversarial scenarios. Because the adversarial attack purpose is to escape the detection, I only consider users pairs who have private interactions and measure the accuracy of successfully detected private interaction given different adversarial attack scenarios.

In this section, I analyze two scenarios: (1) The *evasion attack*, where users in underground forums adjust their behaviors and hide in other users to escape detection, and (2) The *poisoning attack*, where administrators of underground forums generate fake avatars and manipulate their activities to poison the data to prevent their users'

Table 3.8: Detection performance of user pairs containing top $n\%$ of publicly active users.

Top N	Performance	AdaBoost	MLP	RF	PI Coverage
	Precision	**0.94**	0.93	0.92	
5%	Recall	0.97	0.95	**0.98**	79.2%
	F1 Score	**0.95**	0.94	**0.95**	
	Precision	**0.94**	0.93	0.93	
10%	Recall	0.96	0.95	**0.97**	88.9%
	F1 Score	**0.95**	0.94	**0.95**	
	Precision	**0.93**	0.92	0.92	
15%	Recall	0.96	0.94	**0.97**	93.1%
	F1 Score	**0.95**	0.93	**0.95**	

private interactions from being detected.

3.5.1 Evasion Attack

Evasion attacks refer to adversaries in underground forums that adjust their behaviors to hide in the crowd to escape detection. By analyzing the features I used in the detector, I notice that some of them can be modified if adversaries intentionally change their behaviors in the underground forum. I have marked each feature as changeable, unchangeable, or partial changeable in Table 3.5. *Membership* and *Banned* are partially changeable features because their statuses are not fully controlled by the users. For example, a user can change his/her behaviors in the underground forum to be banned, but recover his unbanned status from banned is decided by the administrators. Also, *Leecher* in the *Reputation* can be changed by adversaries depending on how much the contribution the user makes to the underground forum. However, *Reputation* and *Like* are rated by other people that are not controlled by

the adversary.

In the evasion attack, I focus on two main situations: adversaries modify their changeable features without a strategy and with a strategy. I leave as future work the more delicate adversarial machine learning schemes on my model, as well as the assessment of the robustness of the detector against more sophisticated data evasion attacks.

Non-strategic Attack

In the non-strategic attack, adversaries do not know what features are used in the detector, and they attempt to assign random values to all changeable features by adjusting their activities. In this situation, I consider two kinds of attacks: (1) single-user attack, where one user does not want his/her private interactions to be detected, and (2) two-user attack, where two users try to prevent their private interactions from being detected.

Single-user Non-strategic Attack. In this attack, the adversary does not consider a specific private contact user, so this user only modifies his/her changeable profile and activity features to random values. To evaluate the robustness of the detector to this attack, I randomize the value of each changeable feature within a reasonable scope, which are determined by sampling from a subset of users.

It is worth pointing out that changing an adversary's activity feature values can influence his/her interaction feature values with other users. For example, the number of common topics between two users is impacted if one of the users changes his/her *Topics* value. Because the user can delete posts from topics and make new posts in new topics, or just delete or make new posts, it is difficult to know how the change impacts the number of common topics between the users. Therefore, I use

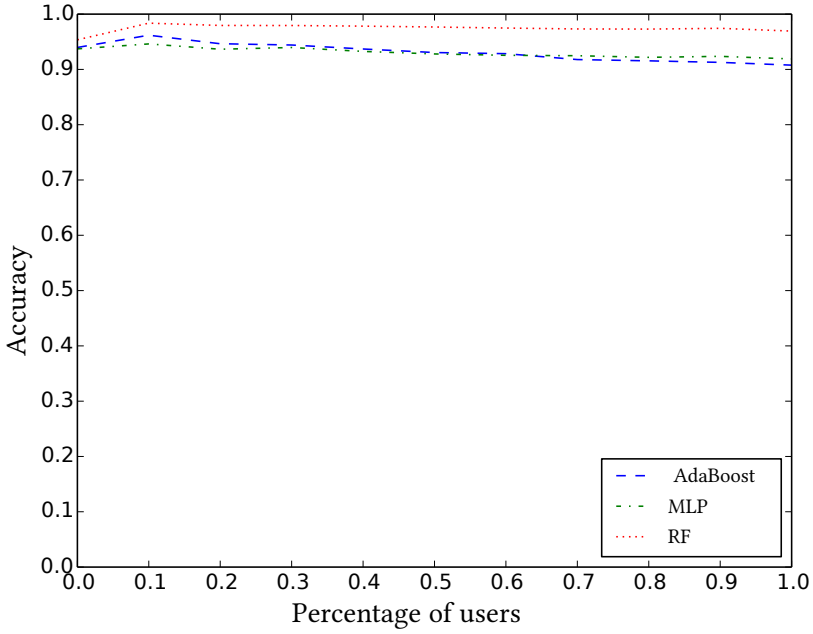


Figure 3.6: Detector performance on the single-user non-strategic attack.

Equation 3.1 to adjust the interaction feature values in each of the instances.

$$InteractionVal' = ChangeableVal' \times \frac{InteractionVal}{ChangeableVal} \tag{3.1}$$

In this example, *InteractionVal'* is the adjusted number of *CommonTopics*. *ChangeableVal'* is the randomly generated number of *Topics*. *InteractionVal* is the original number of *CommonTopics*, and *ChangeableVal* is the original number of *Topics*. To have fair results, I perform the evaluation 1,000 times, and the average results are shown in Figure 3.6.

Figure 3.6 shows the performance of private interaction detection when an adversary modifies his/her changeable information without a strategy by observing differing percentages of other users. As shown in Figure 3.6, my detector is robust to this kind of attack and RF outperforms other algorithms. I notice that the successful evasion rate decreases when considering a larger percentage of users.

Two-user Non-strategic Attack. In this attack, two adversaries have clear private contact targets and try to avoid detection of their private interactions. Therefore, there are three methods to perform this attack: (1) both adversaries change their changeable features in their profiles and activities, and keep the interaction features the same, (2) both adversaries modify their changeable features, and (3) both adversaries only modify their changeable interaction features. To simulate this attack, I randomize the value within a reasonable scope by sampling from a subset of users. Note that interaction features and their corresponding activity features have a relationship that constrains the randomly generated values—e.g., in the first method of this attack, as *CommonTopics* value is not changed, both adversaries' new *Topics* values should be between *CommonTopics* and maximum *Topics* value of a subset of users.

Figure 3.7 shows the detector performance on the two-user non-strategic attack with different methods by sampling different percentage of users. As shown in Figure 3.7, the detector is robust against the two-user non-strategic attack, with more than 80% accuracy in general. Also, RF outperforms other algorithms in all methods; modifying the interaction feature values can impact the RF performance. Additionally, in the two-user attack, adversaries only need to consider 10% of users' information to obtain their considerable evasion rate.

In summary: the detector is robust to the non-strategic evasion attacks, and two-user non-strategic attacks are more challenging to the detector than single-user non-strategic attacks. In addition, RF always outperforms other algorithms in my evaluations.

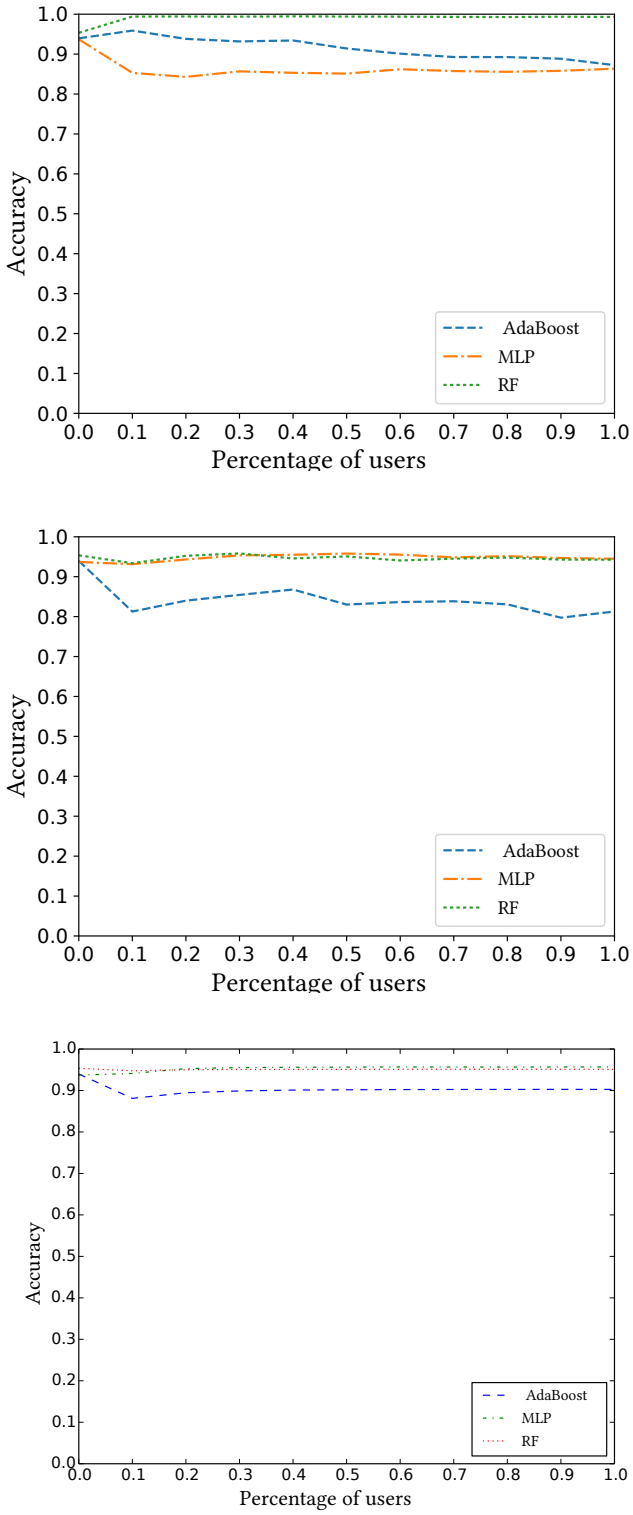


Figure 3.7: Detector performance on different two-user non-strategic attack methods.

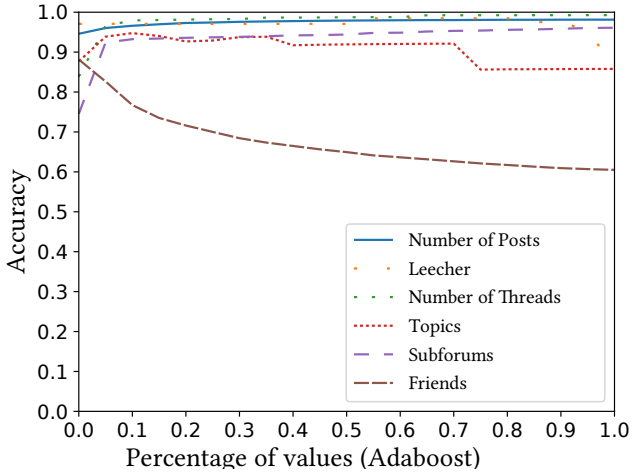
Strategic Attack.

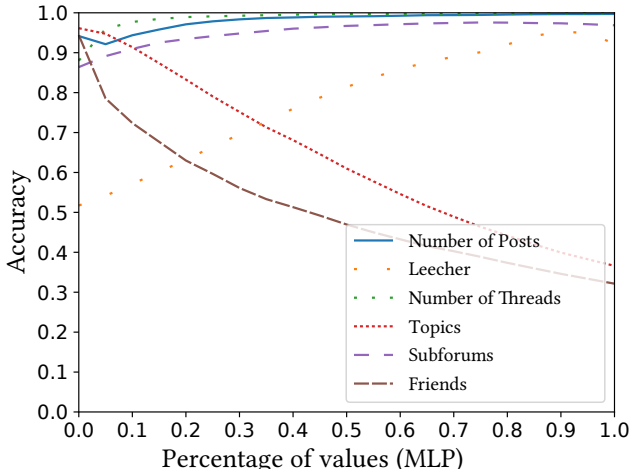
Since many publications discuss machine learning based detectors, such as [59], and the publicly available information in the underground forum is limited, it is possible for adversaries to guess the potential features used in the detector. Therefore, to hide themselves in the crowd, adversaries are motivated to assign specific values to a minimum number of features. In this section, I assume adversaries already know the changeable features and the value scope of each feature. In this situation, I still consider the aforementioned two kinds of attacks: (1) single-user attack and (2) two-user attack.

Single-user Strategic Attack. In this attack, an adversary does not consider a specific private contact user, so this adversary only modifies changeable features in his/her profile and activity. To evaluate the robustness of the detector, an adversary only assigns a specific value to one feature at a time. I also adopt the same approach to adjust interaction feature values (Equation 3.1).

Figure 3.8 shows the detector performance when a user performs a single-user strategic attack in terms of different algorithms. The x-axis shows within a reasonable value range of a feature, the value that will be assigned to the feature. The y-axis indicates the accuracy of successfully detected private interactions. As shown in Figure 3.8, the detector with RF has the most robustness (the lowest accuracy is 83.3%) to the single-user strategic attack and the MLP is the least robust one with only 32.2% accuracy. Additionally, *Friends, Topics,* and *Leecher* impact the detector more significantly than other features. Compared with the single-user non-strategic attack, this attack can increase the adversaries chance to evade detection.

Two-user Strategic Attack. In this attack, adversaries assign a specific value to one type of their changeable features at a time. For example, both users modify





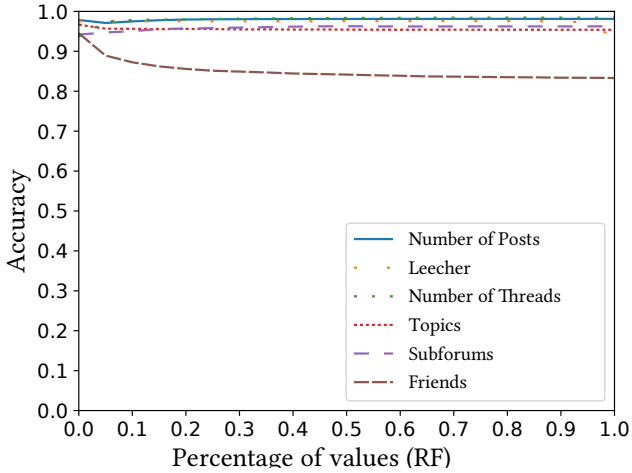


Figure 3.8: Detector performance on the single-user strategic attack.

their *Topics* features, while keeping other feature values unchanged. As explained previously, interaction features and their corresponding activity features have a relationship that constrains the value scope.

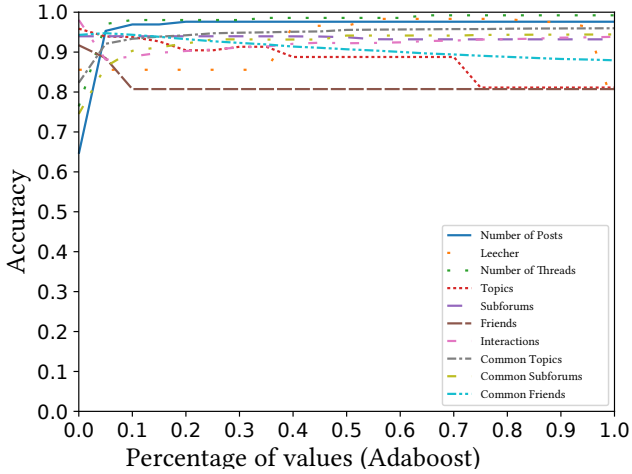
Figure 3.9 shows the detector performance when two adversaries perform a strategic attack in terms of different algorithms. The x-axis shows within a reasonable value range of a feature, the value that will be assigned to the feature. The y-axis indicates the accuracy of successfully detected private interactions. As shown in Figure 3.9, RF is the most robust algorithm in the detector, and its lowest accuracy is 91.2%. In contrast, MLP has the worst performance that is 3.9% accuracy. Also, to my surprise, interaction features do not impact the detection performance significantly, as the lowest accuracy are obtained when modifying *Friends, Topic,* and *Leecher* in Adaboost and MLP based detectors. Although *Interactions* is more influential than other features in RF, the detector still has more than 90% accuracy (see Figure 3.9). Comparing this attack with the single-user strategic attack, although the two-user strategic attack has the lowest accuracy in MLP, frequently the single user strategic attack is more challenging to my detector.

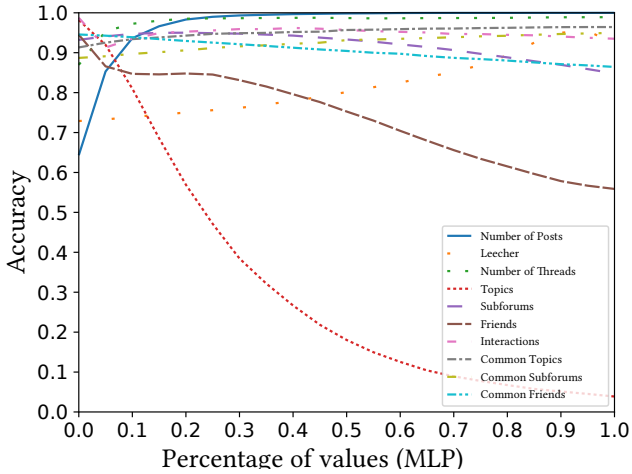
In summary: strategic attacks have a higher chance to evade detection than non-strategic attacks. Additionally, single-user attacks are more challenging than two-user attacks in the strategic attacks. Also, interaction features are less influential than profile and activity features.

Counter Evasion Attack.

To counter the evasion attack, I evaluate my detector robustness with *only using unchangeable features*. The new evaluation indicates that the detector still has considerable performance, shown in Table 3.9.

Figure 3.10 depicts the ROC curves of detecting private interactions by using





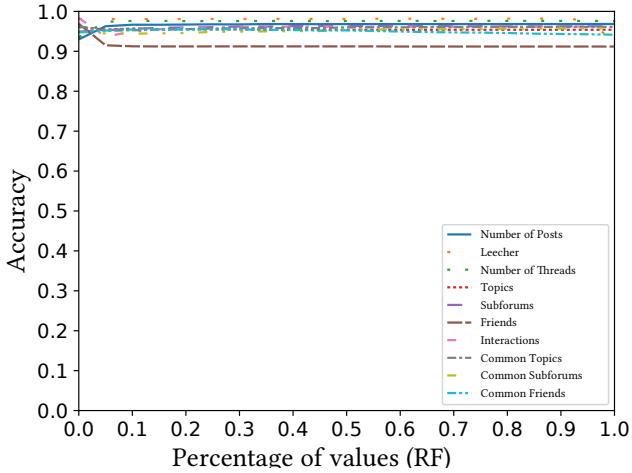


Figure 3.9: Detector performance on the two-user strategic attack.

Table 3.9: Detection performance with unchangeable features.

Algorithm	Precision	Recall	F1 Score	Accuracy
AdaBoost	0.84	0.86	0.85	0.85
MLP	0.84	0.91	0.88	0.87
RF	**0.85**	**0.94**	**0.89**	**0.89**

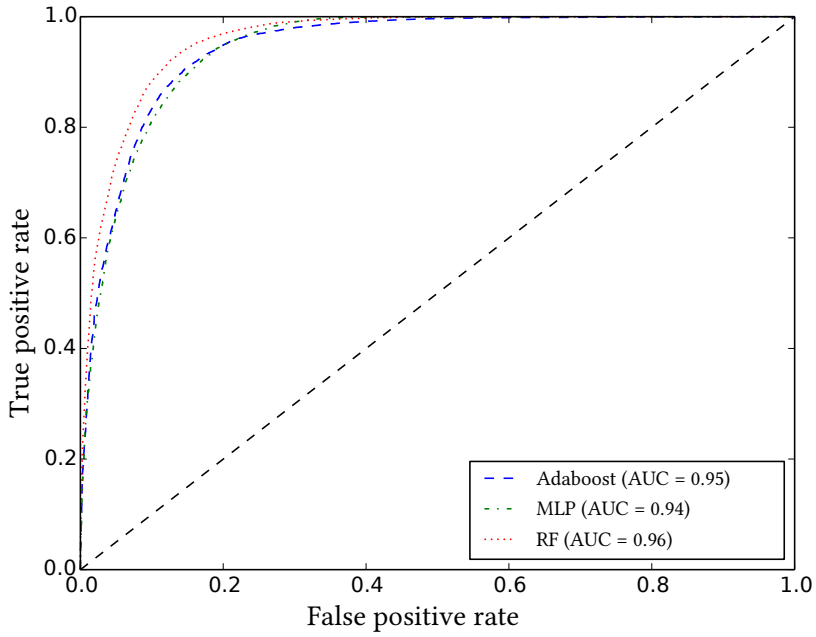


Figure 3.10: ROC curves of detection by using unchangeable features.

unchangeable features. In general, using unchangeable features has worse performance than using all features by comparing this ROC curves with Figure 3.3 and Figure 3.5. In particular, all algorithms can have more than 0.90 TPR with 0.18 FPR. Also, RF outperforms another two algorithms.

3.5.2 Poisoning Attack

To make underground forums operate properly, attract more users, and protect their users' privacies, administrators of such underground forums need to take actions to help prevent their users' private interactions from being detected. As administrators have fully control of the underground forums, they can generate fake avatars and manipulate their activities to make false private interaction samples to pollute the data.

By considering the approach to create fake avatars, there are two types of poisoning attacks: (1) the *random poisoning attack*, where all individual feature values of the fake avatars are generated randomly within a reasonable scope based on all users' information, and interaction feature values of fake avatars are generated based on their individual features. (2) The *normal-user-based poisoning attack*, where administrators find out all normal users, who never have private interactions from the database, and create fake avatars by using normal users' information: while constructing the false samples, the interaction feature values are randomly generated that are within reasonable scope based on two randomly selected fake avatars.

Note that I *do not* construct false samples between fake avatars and real users while considering practical situations. Letting a fake avatar privately contact a real user will provide a bad experience to the user because it means that the user has strange private messages with unknown people. This could lead the user to feel that his/her account is stolen.

To evaluate the robustness of the detector to this attack, I first split the clean dataset into training and testing datasets. Secondly, I generate different numbers of false private interaction samples and then mix them with real training dataset. Finally, I build my detector based on the polluted training dataset and apply the

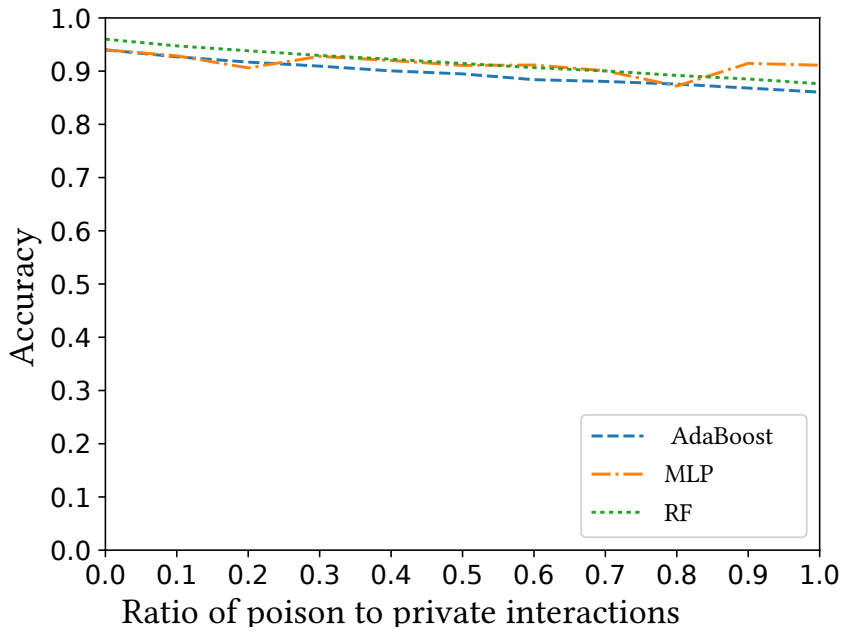


Figure 3.11: Detector performance on the random poisoning attack.

testing dataset to evaluate the detector performance.

Figure 3.11 and Figure 3.12 show the detector performance when administrators perform two types of poisoning attacks by injecting different numbers of false private interaction samples. The x-axis shows the ratio of false samples to the real private interactions, and the y-axis indicates the accuracy of successfully detected private interactions in the testing dataset.

As shown in Figure 3.11 and Figure 3.12, the detector is robust to both types of poisoning attacks, and the performances are very similar. In general, MLP outperforms other algorithms in the poisoning attack with the lowest 0.91 accuracy in random poisoning attack and 0.89 accuracy in normal-user-based poisoning attack. Additionally, injecting more false private interaction samples will decrease the detector performance, but the influence is limited. In the meantime, by comparing the detection performance in the different poisoning attacks, the normal-user-based

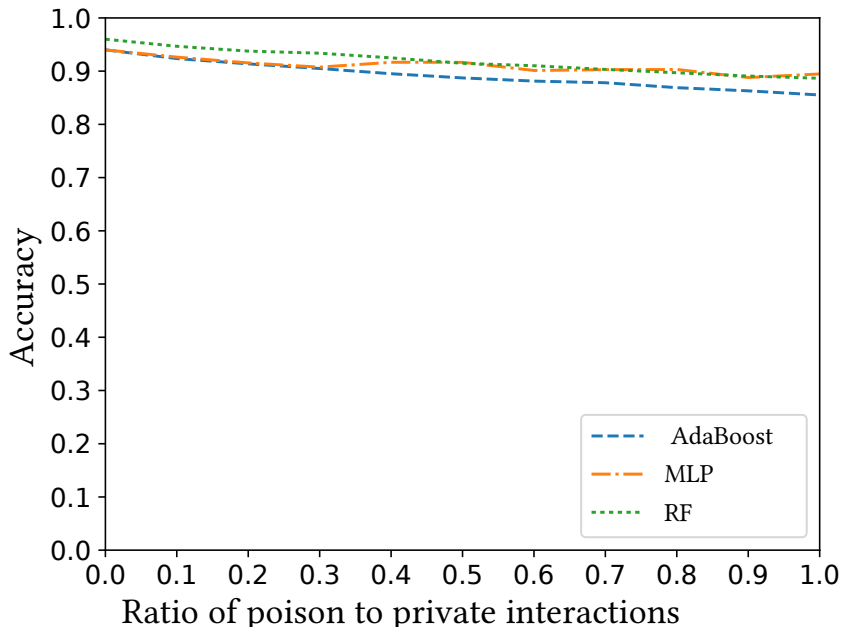


Figure 3.12: Detector performance on the normal-user-based poisoning attack.

poisoning attack is more challenging to the detector.

3.6 Discussion

In this section, I explore the limitations of the data analysis and private interaction detection approaches, and I present the direction of my future work.

In this paper, I use Nulled.io as the subject in my study. Although Nulled.io is one of the most popular underground forums and can be representative for the security research for private interactions, a single forum may be insufficient for data analysis and private interaction detection. I will look for and investigate more data for future work.

For data analysis, I group messages into different categories in terms of contents and purposes. The categories are generated manually based on 1000 samples of public and private message in respective. Due to the limit of samples, the categories may not

be complete. In the future, I will look into approaches towards complete categories for both content and purposes. Moreover, I label messages by applying SVM with supervised classification. However, the SVM model may be imprecise in labeling messages. Data labeling is known to be open in data analysis research. I leave more accurate labeling as future work.

For private interaction detection, I test the robustness of the detection model against adversarial machine learning attacks such as data evasion and data poisoning attacks. For both types of the attack, I consider hard-coded strategies for data generation. One future direction is to test my detection model on more sophisticated adversarial machine learning techniques [9, 24, 116]. Also, I will explore more robust machine learning models for private interaction detection, such as to apply the machine unlearning technique [20] to the current model.

3.7 Related Work

Analysis and measurement of underground forums and marketplaces. Research efforts have been invested in understanding the organizational structure and social activities of underground forums and marketplaces [5, 71, 114]. Motoyama et al. studied six underground forums for understanding what the products and services were exchanged [71]. Also, researchers tried to identify anonymous authors of texts in underground forums by analyzing their writing styles [5]. Zhao et al. analyzed social dynamics relevant to net-centric attacks to discover adversarial evidence [114]. Additionally, Hao et al. analyzed the reshipping service from underground forums to show how cybercriminals monetize stolen credit cards and the relationships between different actors who are involved in this scam activities [38]. Also, Thomas et al. investigated web services that create and trade fraudulent accounts by cybercriminals in underground markets [104]. Even though Radianti et al. pointed out that users in

underground forums and marketplaces prefer to discuss details in private communication channels [85], private messages in the underground society have been largely overlooked.

Messaging in online social networks. People like to post diverse types of message to share their status, moods, opinions, etc., in online social networks. The motivations and purposes of messaging in online social networks have been studied [54, 61, 70]. In the meantime, researchers also investigate how the personality and motivations related to the communications in online social networks [87, 90]. Also, many works are conducted to analyze the text contents from different aspects, such as extracting and categorizing topics [60, 70**?**], analyzing the text to discover the social structure [27, 65] and showing users' sentiments [42, 51, 63, 74]. However, in underground forums, the messages are full of leetspeak, cyber jargons, and users' motivations are different from using public online social networks. In the meantime, users prefer to show their actual purposes in private messages instead of public posts.

Link prediction in online social networks. Link prediction, which has been widely used to suggest friends in online social networks [7, 23, 26, 59, 89, 108], inspires us to design our private interaction detection algorithms because the private interaction is a kind of hidden link between users in the underground forum. Even though they share similarities, link prediction in public social networks and private interaction detection in underground forums are fundamentally different: 1) most link prediction approaches are based on network topology analysis [28]. They assume if two users have shared friends it is highly possible they have or should have a direct connection. However, in underground forums, users do their best to hide their real identities. Hence, the connection between users in the underground forum is not based on the real-world identities, but the anonymous public interactions and 2) in public social networks, users usually use their real identities and profile informa-

tion [30]. Nevertheless, the self-provided information in an underground forum may not be trustworthy and cannot be used for the detection [45].

3.8 Conclusion

Analyzing underground forums and marketplaces is of great importance to understand and combat cybercrime and illegal activities. Even though research efforts have been invested in understanding the organizational structure and social activities of underground forums, private messages have been overlooked. In this chapter, we analyze an underground forum Nulled.io to understand what users discuss in private messages, why users are contacted privately, etc. In addition, we designed machine learning models that take the characteristics of underground forums into account to detect private interactions between users. The results showed that our models are effective in detecting private interactions and can withstand attacks.

The analysis of private interactions has led me to notice that underground forums have evolved into criminal freelance markets where criminals trade illicit products and provide cybercrime services, allowing them to create new cybercrime models that have been largely ignored by current security communities. In Chapter 4, I will discuss an emerging sophisticated global scam service, *"Concession-Abuse-as-a-Service"*, operating in underground forums, which takes advantage of online retailers' return policies (through social engineering) and the exploitation of loopholes in company protocols.

Chapter 4

AN ANALYSIS OF CONCESSION-ABUSE-AS-A-SERVICE

4.1 Introduction

In concession abuse attacks, scammers leverage social engineering techniques to exploit the return policies of targeted merchants and obtain a *concession* (in the form of a refund or a replacement item) without returning any originally purchased products. Recent news of Amazon being scammed out of €300,000 and $1.2M in 2017 and 2019 in two targeted *concession abuse* attacks reveals the tremendous (and growing) damage that such attacks can cause [37, 112]. These attacks become particularly heinous when scammers obtain such refunds using stolen accounts that belong to legitimate customers. Once successful, scammers monetize the refunds (often gift cards or replacement goods from the retailer) through services in the underground economy. Because offering concessions to appease distressed customers is a crucial business practice for retailers, these scams place companies in the difficult position of choosing between scam mitigation and the happiness of legitimate customers.

A perception by vendors who fall victim to concession abuse may be that these attacks are isolated incidents and can thus be resolved in an ad-hoc fashion. However, through a comprehensive analysis of underground forums and a concession abuse provider, I find that such attacks operate at scale, target merchants across multiple industry sectors, involve complex coordination between different underground actors, and overcome current industry best practices and mitigations to reliably yield success for the criminals.

In this chapter, I show that concession abuse is, in fact, a prevalent criminal

business service to which even unsophisticated cybercriminals can *subscribe* and subsequently profit with minimal investment. I refer to this ecosystem as *Concession Abuse as a Service* (CAaaS). The unsophisticated customers of CAaaS (*scam initiators*) request that attackers (*service providers*) engage with a targeted merchant to execute the scam. The scam initiator's ultimate goal is to obtain money from a purchased order via a concession from the merchant after paying a nominal commission to the service provider.

Despite its surface simplicity, CAaaS is a sophisticated online criminal industry that coordinates a diverse range of parties to facilitate key stages of the scam. An end-to-end supply chain of illicit services underpins CAaaS and provides components such as stolen account credentials [102], forged documents [43], and reshipping services [38]. Given the fact that existing mitigation approaches cannot effectively protect merchants from CAaaS [37, 112], and the wide range of threat actors that the scam entails, the research community must seek *systematic and proactive mitigations* to stop concession abuse across the entire ecosystem. To propose such mitigations, I first carefully study CAaaS to understand the *economics* and *implementation* of the attacks, and then conduct a survey as a preliminary evaluation of the proposed mitigations.

To this end, I performed an in-depth analysis of criminal communications on four popular underground forums, where I discovered 2,251 service providers of CAaaS scams who, collectively, target 264 merchants. Both scammers and targeted merchants are distributed globally, and I found that CAaaS has not only remained active but is becoming more prevalent in recent years, despite the evolution of retailer return policies to prevent fraud. I identified underground communities in which users discuss scam questions, share their success and failure experiences, and even post tutorials for beginners. I found that these resources help train ill-intentioned users

to become CAaaS service providers *within months*. Additionally, I joined a private discussion group run by a service provider and found the provider helped refund at least $81,159.27 over three months.

Prior work has examined social engineering skills [44, 48] and their applicability to traditional web-based phishing attacks, as well as persuasion techniques that manipulate people into performing actions or divulging confidential information [8, 17, 33, 72] and the phenomenon of criminal reshipping services [38]. General exploitation of merchants' return policies was studied in an *offline* context [95], and CAaaS combines and enhances these areas of cybercrime to target a unique part of the attack surface against retailers.

By performing the first such study of CAaaS, I help identify ways to disrupt the economics of the scam and empower vulnerable retailers to implement proactive defenses. My contributions are thus as follows:

- I present the first study of the operations of an emerging threat, *Concession Abuse as a Service*, by examining the wide range of actors and supporting services involved in the scam and its economics.
- I characterize techniques that allow CAaaS to effectively defraud merchants, as well as failure cases and limitations of such techniques.
- I identify attributes to fingerprint CAaaS, propose mitigation approaches usable by merchants, and evaluate these approaches through merchant interviews and a user survey.

4.2 Overview

Concession abuse is a type of cybercrime that typically targets online merchant services. [1] In such scams, a malicious customer seeks to receive a concession—a free replacement or a refund—from a *targeted merchant* by socially engineering the Customer Service Representative (CSR) and exploiting the return process. If the scam succeeds, the criminal will get a free replacement or a refund, either of which can be monetized through additional intermediaries (see Section 4.3.4).

Concession abuse has evolved from ad-hoc scams into a *service* that has grown both in its complexity and effectiveness. In this transition, each scammer's role has expanded amid an environment in which attacks can occur on a large scale, and where individual cybercriminals can quickly gain expertise in their specific roles. Consequently, the barrier to entry has been greatly lowered such that even unskilled criminals can leverage and profit from concession abuse.

In this chapter, I study the ecosystem of concession abuse as a service (CAaaS). In particular, I investigate the following research questions:

1. How does concession abuse work as a service (Section 4.3)?
2. What are the characteristics of CAaaS, and on what scale does it operate (Section 4.4)?
3. What do criminals do to execute concession abuse successfully, and when do certain scams fail (Section 4.5)?
4. How can merchants prevent concession abuse from succeeding at scale (Section 4.6)?

[1] Although traditional concession abuse can also target brick-and-mortar merchants, in this work I focus solely on merchants with an online presence, as offline attacks do not have the same scaling potential and are addressable through physical security approaches [46].

Table 4.1: Popularity statistics for the forums I analyzed.

Forum	# Threads	# Posts	# Users	Data Covered
NULLED	121,486	3,495,593	599,085	Jan 2015 – May 2016
MPGH	325,626	3,614,061	323,772	Dec 2005 – Feb 2019
SENet	55,560	468,659	15,433	May 2011 – Feb 2019
SIN	56,352	499,257	14,583	Aug 2008 – Dec 2018

Analysis Approach. I used a qualitative approach for Question 1, a quantitative approach for Question 2, and hybrid approaches for Questions 3 and 4. For clarity, I describe each approach in its respective section.

Data Sources I base my analysis of CAaaS on four distinct data sources discussed throughout the remainder of this chapter: threads and posts from underground forums, messages in private criminal groups, interviews with two large (undisclosed) US-based merchants, and a user survey about possible mitigation strategies.

I sought to identify underground forums with a significant focus on topics related to retail scams (the presence of which might imply the respective community's interest in concession abuse). I started with a large forum that had recently suffered a database breach: Nulled.io [78]. Using this database, I could analyze public threads and private messages. I then crawled all the URLs therein to compile a list of candidate forum URLs.

I manually analyzed each publicly accessible forum on this list, and for each that was still online and had at least 100 threads in scam-related sections, I (1) exhaustively crawled its public content and (2) recursively applied the same process to discover other candidate forum URLs. I ultimately identified and crawled four forums suitable for my analysis: Nulled.io (NULLED), SocialEngineered.net (SENet), Sinister.ly (SIN), and MPGH.net (MPGH). I summarize the relative popularity of these forums, at the

time of my data collection in early 2019, in Table 4.1.

Given the fact that commoditized criminal services cater to less sophisticated criminals [75], I believe that my choice of clearnet forums was appropriate for the analysis of CAaaS.

Ethics. I proactively addressed ethical concerns by working closely with my Institutional Review Board (IRB) to obtain their approval and to develop an accepted ethical protocol for this study. First, I do not attempt to identify users from the collected datasets and use anonymous expressions to represent corresponding sensitive information in this chapter. Since my purpose is to analyze CAaaS, I do not focus on particular users in the underground forums.

Second, using leaked or crawling publicly available datasets is an acceptable practice in the study of the underground ecosystem [5, 38, 71, 99]. Since purchasing services from underground forums to collect data with limited affecting other users is also acceptable in the research community [50, 97, 100], I pay for upgrading my accounts to access VIP sections of forums to collect more data.

4.3 Anatomy of Concession-Abuse-as-a-Service

To understand the steps and actors involved in Concession Abuse as a Service, I first conduct a manual qualitative study on the crawled forum threads, artifacts (e.g., attachments and tutorials), and private messages. Due to the high number of forum threads, I randomly selected 4,000 threads (1,000 from each forum) for my analysis. I exhaustively reviewed all of other types of data. I then synthesized my findings to gain a thorough understanding of CAaaS.

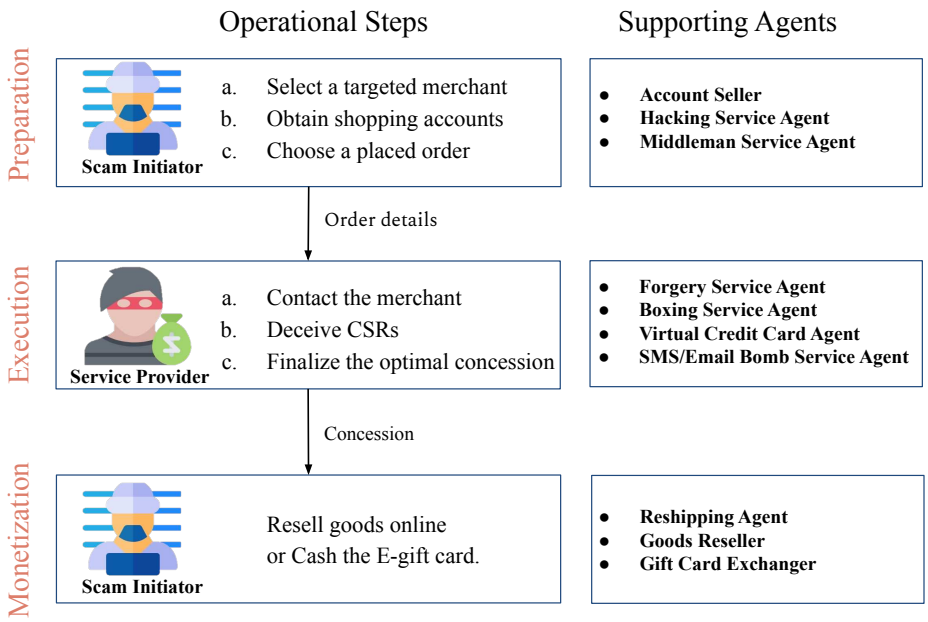


Figure 4.1: The steps and actors in CAaaS.

4.3.1 Scam Actors

At a high level, CAaaS involves two parties: the *Scam Initiator* and the *Service Provider*. A scam initiator is the customer of CAaaS who wants to receive a free concession, and a service provider is a scammer who sells concession abuse as a service. In addition to scam initiators and service providers, other criminal agents play various supporting roles to improve the scam's chances of success and to hide the scammers' identities. I divide the process of CAaaS into three steps: preparation, execution, and monetization, as shown in Figure 4.1.

In the following sub-sections, I describe each step along with the actors involved. To better illustrate the actors in CAaaS, I also show a representative set of their discussions in Table 4.2.

Table 4.2: Quotes from criminals involved in CAaaS.

	Agent	Quote
Preparation	Service Provider	I will be offering my refund service after learning and having successful refunds of my own on many stores. I will list stores that I am the most comfortable refunding ...
	Scam Initiator	I need someone who can replace items from cracked UK amazon accounts, need to be trusted...
	Account Seller	I am selling an amazing Amazon account today, lots of past orders and very easy to get refunds from. I will start the bid at 15$...
	Hacking Service Agent	I'm selling everything you need to start cracking and everything you need to make your own combos, I'm cracking for over 2 years now and i cracked many sites and made nice amount of money, now I'm here selling everything you need for cracking ...
	Middleman Service Agent	you will know me for my SE Guides and HQ Posts on this forum well today I am offering middleman services via Paypal ...
Execution	Forgery Service Agent	I am also now offering general photoshop work, (utility bill, bank statement, etc.) PM me for rates ...
	Boxing Service Agent	Most boxing is $10 – $15, depending on weight and packaging requested. Amazon boxing starts at $15 for under 5 lb, Amazon boxing 5 lb – 10 lb is $20. Want a box with a little weight? $-> $12...
	VCC Agents	I'm Selling VCCs for amazon These VCCs have at 2 bucks on it, so they are good for SEing 10 bucks for 1 VCC Add me on skype...
	SMS/Email Bomb Service Agent	I am offering my email bombing service for w/e you needs, i can offer 200 / 50cents I will only accept BTC...
Monetization	Scam Initiator	Since my last deal feel through i am selling the 4 xboxs i have at my reship. I believe they are all start wars.
	Reshipping Agent	LOCATED IN U.S.A. I reship your packages to anywhere in the world! Prices start at $29.99 and up. Package receiver or sender must pay for shipping ...
	Goods Reseller	I have an ebay account with 100% positive feedback. Looking for someone to supply me with products that I can resell. I have done this before with a few members here with great results ...
	Gift Card Exchanger	Looking to buy AGC, can pay via PP or BTC Looking for 70%.

4.3.2 Preparation

In the preparation step, a scam initiator and a service provider make a deal for an order or a merchant. For a scamming order, the scam initiator provides to the service provider a placed order and the corresponding information.

To obtain sufficient information and scale up the CAaaS business, a service provider may ask scan initiators to fill out a service form, as addressed in their advertisements *"submit the refund form if your order is already delivered."* The form includes detailed questions regarding the order, account, and the expected outcome (e.g., refund or replacement). For example, if a scam initiator places an order, they need to provide the type of payment, preferably "the last 4 digits of the card", and clarify if they have "received or signed for the delivery." For more information, I present a real-world service form in Table A.1 in Appendix A.

Scam initiators or service providers typically prefer not to use their own accounts for better anonymity. *Account Sellers* provide compromised accounts, and *Hacking Service Agents* provide account attacking toolkits. Furthermore, *Middleman Service Agents* moderate the process, keeping both parties anonymous and avoiding scams in the service.

4.3.3 Execution

After the deal is made and the initial order is placed, service providers contact the targeted merchant and attempt to deceive the CSR into providing a concession. In the conversation between the service provider and the CSR, there may be conditions that prevent the concession abuse scam from succeeding. In these conditions, the service provider may leverage the services provided by supporting agents. I list these conditions with the associated supporting agents in categories below, and I will elaborate on each category in Section 4.5.2.

Extra Proof. The CSR may require extra proof for the issued merchandise. A *Forgery Service Agent* helps by providing forged proof such as edited photos.

Return Requirement. The CSR may require the original goods to be returned

prior to issuing the concession. A *Boxing Service Agent* helps to craft an otherwise empty shipping box with the weight expected by the merchant. In the case of high-value items, the box may instead be filled with counterfeit goods.

Credit Card Requirement. The CSR may issue a concession before the original product returns yet to ask the service provider for a credit card number as collateral to ensure the return. In such a case, a *Virtual Credit Card (VCC) Agent* is able to furnish a valid credit card number that would be accepted by the merchant with few dollars balance.

Accountholder Notifications. After the concession is processed, the CSR may send a notification to the accountholder via e-mail or SMS. This increases the risk of being detected if the service provider uses a compromised account. In an attempt to minimize suspicion, an *E-mail/SMS Bomb Service Agent* will help flood the accountholder's e-mail or SMS inbox with messages to drown out alert messages from the targeted merchant.

4.3.4 Monetization

Recall that a scam initiator chooses either refund or replacement. However, the CSR may not provide what the scam initiator wants, and thus the scam initiator must convert the attack outcome to their actual needs. There are three possible scenarios as follows:

Once a service provider succeeds, they will request a refund via an e-gift card or a replacement sent to a specific address.

Replacement to Cash. If the concession is a replacement item, it may be shipped to a *Reshipping Agent* who supplies a third-party address. It is worth pointing out that scammers take advantage of both legal reshipping companies and

drops [38] as the reshipping agents. The scam initiator can then resell the goods directly (e.g., by advertising them in underground forums) or hire a *Goods Reseller* with a trusted reputation in online marketplaces (e.g., eBay). Once the goods are sold, the reshipping agent will mail the goods to the buyer, who may be unaware of their fraudulent origin.

By using reshipping agents and goods resellers, the scam initiator is isolated from both the merchant and the buyer, and can therefore remain safe from detection. Reshipping agents are favored as they often offer free storage for a generous period, which lowers costs for the initiator because they do not need to pay for warehousing. [2]

E-gift Card to Cash. To quickly cash out an e-gift card, the scam initiator can employ a *Gift Card Exchanger* to exchange it for digital wallet balance or cryptocurrency such as Bitcoin. However, this method generally carries higher fees (e.g., 30%, see Table 4.2) due to added risk. To avoid such fees, some initiators will instead use the e-gift card to order an item and then resell it using the aforementioned method.

CAaaS for Buying Discounted Goods. Interestingly, I observe that some service providers even behave as third-party dealers of arbitrary goods. A scam initiator reaches out to the service provider and pays them a heavily discounted price for a specific product (chosen by the initiator). The service provider then uses unrelated orders to obtain one or more refunds from a target merchant that sells this product. Finally, the provider uses the refund(s) to purchase the designated product for the initiator. As a result, the scam initiator gets a product at a price substantially below

[2] One legal reshipping company frequently discussed by scammers (*Reship.com*) provides 60 days of free storage.

retail value, and the service provider gets payment for the service.

4.4 Analysis of CAaaS Features and Scale

As an emerging threat, CAaaS has a number of unexplored aspects, therefore I focus on the following questions:

1. Which merchants and goods do scammers target? (§ 4.4.2)
2. How much do providers earn from the service? (§ 4.4.3)
3. What is the geolocation of concession abuse scammers and their targeted merchants? (§ 4.4.4)
4. Does the scam operate at scale? (§ 4.4.5)
5. How difficult is it for newcomers to learn this scam? (§ 4.4.6)
6. Is the financial loss significant? (§ 4.4.7)
7. What is the overlap between the concession abuse scammers and other types of scammers? (§ 4.4.8)

4.4.1 Analysis Approach

To draw insights about large-scale activity in underground forums that extend beyond the qualitative manual analysis described in Section 4.3, I train a machine learning classifier and apply it to the whole dataset. Our approach is composed of three steps.

Step 1: Data Sampling. I randomly sampled 4,000 threads (1,000 in each forum) from the crawled forum data using *Stratified Random Sampling* [55], and I manually labeled each thread based on its content.

Step 2: Sampled Data Labeling. I designed three separate types of labels for answering the seven questions posed in Section 4.4, and I synthesized the labels based on the empirical analysis on the 4,000 samples.

CAaaS Topic. I classified threads by four CAaaS topics: Advertisement, Purchasing Request, Discussion and Support, and CAaaS-unrelated. These labels help to identify CAaaS-related posts and actors and will be used to answer all the questions.

Scamming Experience. For Question 5, I classified CAaaS-related threads by scamming experience: Successful, Failed, and Neutral experiences. These labels help to identify the conditions and the time that a scam succeeds or fails.

Forum Activity. For Question 7, I classified underground forum activities by Monetization, Hacking, Scam, and Other, and I specified common scams by Email Compromise, Data Breach, Denial of Service, Phishing, and Ransomware referred by common underground forum structures and FBI Internet Fraud definition [32].

Step 3: Data Classification. For each label type, I used the labeled samples to train a well-performing machine learning model and applied the model to the full dataset. I performed three steps to process the raw data [98, 109]:

I first converted text to vectorized features with Term Frequency-Inverse Document Frequency after the threads are converted into tokens and stemmed with Natural Language Toolkit [15]. Each thread is represented as a 108,741-dimension vector. I then applied 5-fold cross-validation, training on four folds and testing on one fold for five repeated times, and synthesized and computed the F1 score for all three classifiers. I evaluated six models: Support Vector Machine (SVM), Naive Bayesian, Logistic Re-

Table 4.3: CAaaS topic statistics for the forums.

CAaaS Topic	# Threads	# Posts	# Users
Advertisement	13,433	280,434	27,089
Purchase Req.	13,817	65,590	9,131
Discussion & Support	30,033	278,590	29,988
CAaaS-Unrelated	501,741	7,452,956	642,167

gression, K-Nearest Neighbors, Multi-Layer Perceptron, and Random Forest. I chose SVM ultimately as it outperformed other models, having F1 scores of 0.88 for the CAaaS topic classifier and forum activity classifier and 0.90 for the CAaaS experience classifier, which are sufficient for cybercriminal ecosystem analysis, as defined by Bhalerao et al. [12].

Table 4.3 shows CAaaS topic statistics for the forums. Note that many users do not have any activity but reading after joining forums, so they are not classified into any category.

4.4.2 Targeted Merchants and Goods

To understand what targeted merchants are advertised, I used Standford NER [34] to tag "ORGANIZATION" tokens in the results labeled CAaaS Advertisements, and then manually reviewed all extracted organizations to remove mistagged ones. By comparing the merchants identified via such an approach with my manually extracted merchants from 200 randomly selected advertisements, the semi-automatic merchant extraction approach can identify 97.8% of targeted merchants. I identify 264 targeted merchants from all advertisements using this semi-automatic approach.

To determine the most popular merchants, I count each merchant's number of times was mentioned in a provider's advertisement. The results show that 1,031 out

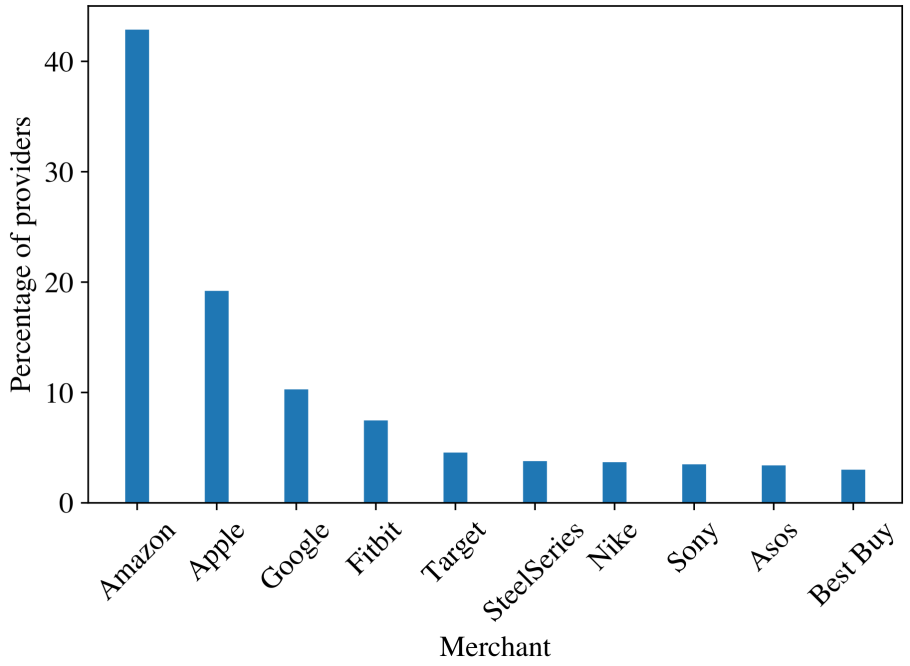


Figure 4.2: Top ten targeted merchants advertised by CAaaS providers.

of the 2,251 service providers explicitly advertise merchants. Figure 4.2 shows the ten most targeted merchants explicitly advertised by the 1,031 service providers.

By manually analyzing 100 randomly selected providers who never mention merchants, I found that: (1) such service providers do not advertise targeted merchants but request to be contacted privately for details (e.g., *"if you are interested pm me"*), (2) they only mentioned the types of goods (e.g., *"items can consist of electronics and jewelry"*), and (3) they put the prior positive experience from other members in their advertisements and leave contact information.

Case Study. I analyzed a service list from a well-known scam service provider in the SENet forum as a case study. The provider has been active since 2017 and holds a top 1% reputation rating. The provider groups the targeted merchants into eight categories and lists Amazon as one dedicated category because of its popularity. For

Table 4.4: Partial concession abuse service list for a top service provider.

Store Category	Payment Method	Store	Limit ($/€)	Items	Pay Rate (%)	Region	Avg Time
Clothing	Credit/Debit Card	Abercrombie & Fitch	No Limit	Multiple	25%	Worldwide	1 Day
		Macys	No Limit	One	25%	USA	1 Day
		Hollister	No Limit	Multiple	25%	Worldwide	1 Day
		Zappos incl Luxury	30,000	Multiple	25%	USA	1 Day
		Armani	3,000	Multiple	25%	Worldwide	10 Day
	PayPal	Stone Island	No Limit	Multiple	15 – 25%	Worldwide	2 – 3 Weeks
		StockX	No Limit	One	15 – 25%	Worldwide	2 – 3 Weeks
		YOOX	No Limit	Multiple	15 – 25%	Worldwide	2 – 3 Weeks
		Dolce Gabbana	No Limit	Multiple	15 – 25%	Worldwide	2 – 3 Weeks
		Mr Porter	No Limit	Multiple	15 – 25%	Worldwide	2 – 3 Weeks

brevity, I show one category of the services in Table 4.4, and the full service list in Table D.1 in Appendix D. Because there are 157 merchants in the original list, I list five of the highest *Limit* merchants in each category.

As shown in Table 4.4, I notice that the payment method impacts the service. Scam providers are more confident in working on high-value orders paid by PayPal than by credit or debit cards because of the higher *Limit*, although refunding PayPal orders takes a longer time. Buyer protections offered by third-party payment processors may provide scammers additional avenues for getting refunds. Also, according to one of the companies I collaborated with, some merchants do not actively engage in investigations or disputes from third parties, enabling scam providers to bypass merchants when getting refunds.

Each provider's service list reflects their experience in scamming different merchants, so the *Limit, Items, Region* and *Average Time* can vary between providers. For example, the scam service provider of Table D.1 can work on Walmart orders with multiple goods and a $30,000 price limit, but another scam service provider can only refund one item in an order from Walmart with a $600 limit. Note that providers also offer to scam merchants that are not in their service lists.

Targeted Goods. From a service provider's perspective, as shown in Table D.1, the provider cares more about the store, payment methods, order value, region, and the number of items than the goods themselves. From a scam initiator's perspective, they either want a refund for orders in compromised accounts (in which case they cannot arbitrarily choose the good), or they use their account and will accept any high-value good. Therefore, scam initiators do not have particular targeted goods; instead, they accept all kinds of goods, from high-value electronics to clothes, food credits, or even baby products (e.g., *"lots of free food (got a $150 store credit for Pizza Hut one time that was amazing) and free diapers when my kids were babies."*).

4.4.3 CAaaS Service Fee

By studying a randomly selected set of 100 service providers from the four underground forums, I discover that service providers will either charge a percentage of the order value (i.e., the requested refund amount), or a minimum fee, whichever is greater. For example, the provider referenced by Table 4.4 will charge 15% to 25% or a $35 minimum. The fees primarily depend on the merchant, order price, and original payment method: *"Clothing Store PayPal Claims: 25% under $/€ 5,000, 20% under $/€ 7,000, and 15% above $/€ 7,000."*

Additionally, there is no significant difference in the fee percentage and minimum fees between service providers in the data. I conclude this by analyzing these randomly selected providers while considering three factors: (1) their *Reputation*, (2) the number of *Likes*, and (3) *Post Time* of first service advertising. *Reputation* and *Likes* are peer-rated indicators as social proof of a provider's trustworthiness and contribution to the underground forum, whereas the *Post Time* reveals the service starting time. My results show that regardless of the rank of providers' *Reputation*, *Likes*, or *Post Time*, each provider's minimum and maximum rates are nearly 15% and 30%,

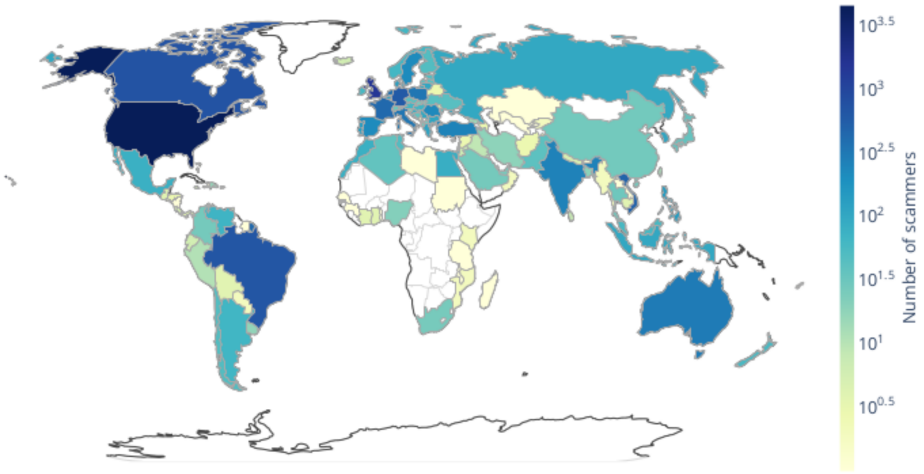


Figure 4.3: Geographical distribution of concession abuse scammers from the NULLED forum.

respectively. Also, their minimum fees vary between $30 and $50.

4.4.4 Geolocation of Scammers and Merchants

I extracted 15,450 IP addresses of members engaged in CAaaS threads from the NULLED database. Then, I used the *IP2Location* service [13], which is accurate at the country level [82], to determine the country of CAaaS scammers.

At the time of the study, I identify 1,674 (10.8%) anonymous IP addresses (e.g., VPN services, open proxies, Tor exits, hosting providers) by using the *IP2Proxy* database [67]. While there may be additional unknown proxies not identified by *IP2Proxy*, using *IP2Proxy* can provide insights into scammers' geographical distribution by excluding popular and public anonymous IP addresses.

As shown in Figure 4.3, the remaining IP addresses are globally distributed, and the US, UK, and Canada are the top countries, accounting for 43.3% of these addresses. Also, most service providers (84.8%) are in Europe and North America, and only 11.7% of providers hide their IP addresses in underground forums using an

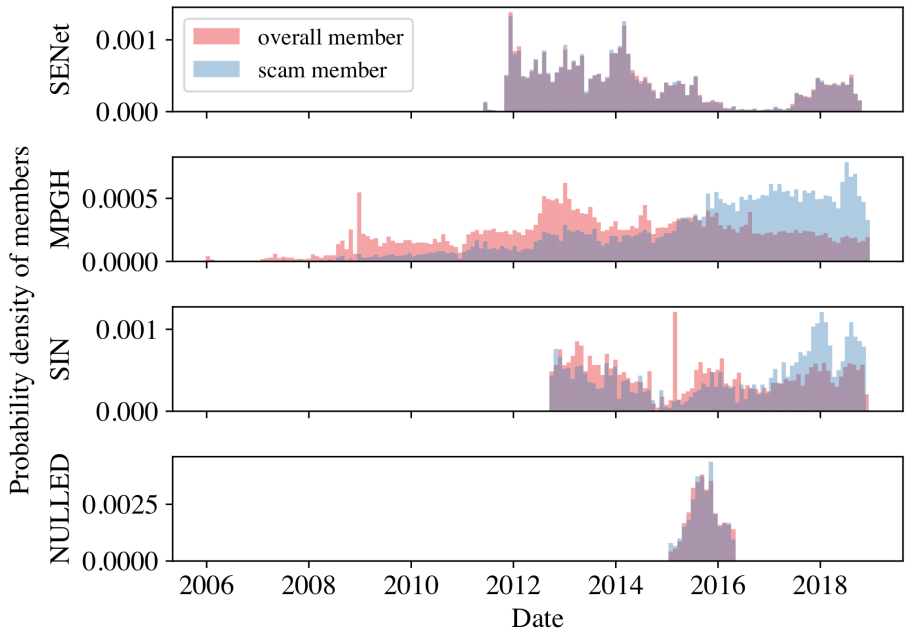


Figure 4.4: Trends in new scammer registrations and total forum members, monthly from 2006 to 2018.

anonymous IP address known to *IP2Proxy*.

Additionally, targeted merchants are distributed worldwide. Table D.1 shows the service provider targets, which include merchants in Europe, Asia, and North America, such as YOOX, Lenovo, and Microsoft. Also, scammers target large merchants who have a presence in multiple countries, such as Amazon. In Table D.1, the provider explicitly demonstrates his capability of scamming Amazon in seven countries. The provider can refund the highest value orders from Amazon US and take the shortest time from Amazon Netherlands.

4.4.5 Scam Scale

In this section, I studied the scale of the CAaaS community. I counted the number of newly registered scammers and overall members within a 30-day sliding window

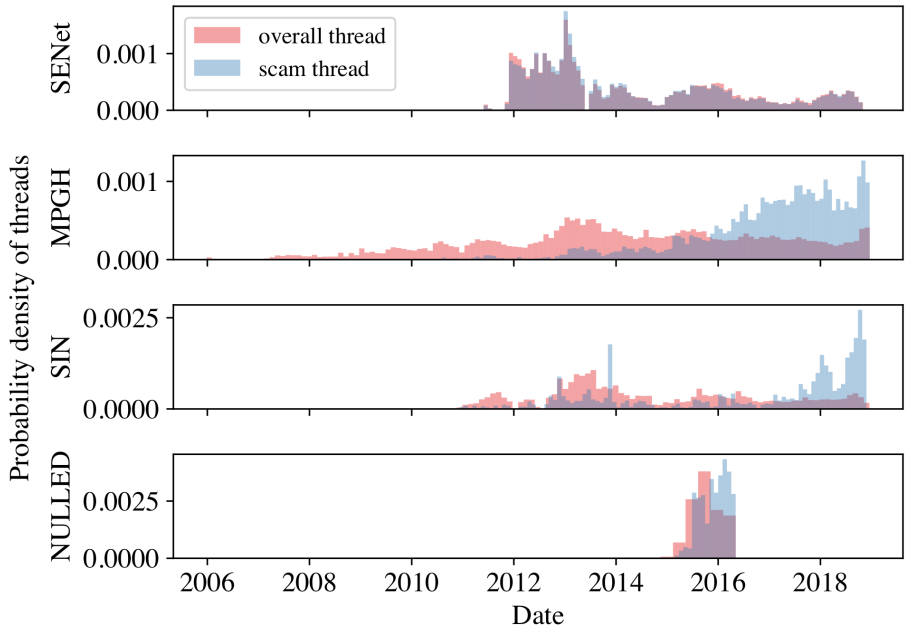


Figure 4.5: Trends in newly created scam threads and total threads, monthly from 2006 to 2018.

by the forum to compare their registration patterns. I used probability density to normalize the count and demonstrated the pattern differences of newly registered scammers and overall members, as shown in Figure 4.4.

In general underground forums, MPGH and SIN, where CAaaS is not the main content, the number of new CAaaS scammers has been increasing, but the number of new overall members has not increased significantly, and even declined since 2016. Because SENet is a forum primarily for CAaaS, the patterns of new scammers and overall members are very similar, showing an increasing trend since 2017. For another general hacking forum, NULLED, I do not observe significant pattern differences. One possible reason could be that the data in NULLED is between 2015 and May 2016.

I also studied the activity of users discussing CAaaS in underground forums. I considered the number of newly created scam threads and overall threads in each

forum (as opposed to the number of replies) because new threads are indicative of new instances not previously discussed. To compare the thread patterns effectively, I normalized the count and depicted the probability density of new scam threads and overall threads over time by forum in a 30-day sliding window, as shown in Figure 4.5.

I observe significant climbing trends of new scam threads in MPGH, SIN, and NULLED forums, while overall threads have stable or even decreasing trends. Although there is a slightly increasing trend since 2017 in the SENet forum, fewer threads were started compared with earlier. A possible explanation for these threads could be an active rumor within the underground communities, which states that the SENet forum was taken down by law enforcement, and it now is a trap for scammers.

4.4.6 From Novice to Seasoned Scammer

Based on my manual analysis of the four forums, I notice the significant amount of resources for novices helps them learn and become expert scammers within a short period of time.

Scam tutorials are widespread in underground forums. For example, Table B.1 in Appendix B shows a scammer advertising about tutorials of the concession abuse scam, where customers can buy the core book plus any other selective tutorials from the scammer. These books can lower the learning curve and provide full-service guidance for scammers from learning scam tricks to running their scam services. For example, refunding through PayPal can have higher profits, which is also recommended by providers (see Table D.1), so novices can pay €179.90 and learn the method and tricks from the selective tutorial "PayPal refunds". Moreover, "Start your own service" and "1-ON-1 Mentorship" can help a scammer start his service and provide service guidance when necessary.

Scammers share their scamming experience to inspire and support other scammers

```
Support seeker: ... I've been trying to SE a google pixel xl 2  ...
both times everything went well until they asked for a proof of
purchase. ... I'm not exactly sure what I'm doing wrong ...
Support provider 1: Gift/Giveaway doesn't work too well anymore for
UK. I'm assuming you're trying UK.
Support provider 2: So get a POP and give them fake receipt
Support provider 3: Fake Amazon POP's work. If you want to be safe
you can crop out the order number so they can't verify it
```

Figure 4.6: Support received from experienced scammers.

as well. For example, one scammer shares that *"It was pretty easy, I ordered a laptop from DX and I contacted them I didn't got it so they sent a new one."*, and another group of scammers provide suggestions as shown in Figure 4.6.

To understand the difficulty of learning to perform concession abuse scams, I measured the time a novice needs to succeed in their first scam based on their post date and joined date extracted from the raw HTML files. I first identified novices by finding the accounts that initiate a CAaaS-Discussion & Support thread (to seek help), do not provide any services. Then, I leveraged the scamming experience classifier 4.4.1 to find scammers who share both failed and successful scamming experience, and the first failed experience date should be earlier than the first successful experience date. Through this method, I identified 94 novice scammers that matched this description. Note that there are more novices in underground forums, and I only select those who share their scamming experience. To ensure these identified scammers are indeed novices, I manually analyzed all of their posts in the underground forums: the posts are either learning scam skills or asking for help. Moreover, none of them attempt sophisticated techniques such as starting a scam-related business, based on my manual analysis of their posts.

I then identified the amount of time it took them to post about their first failed

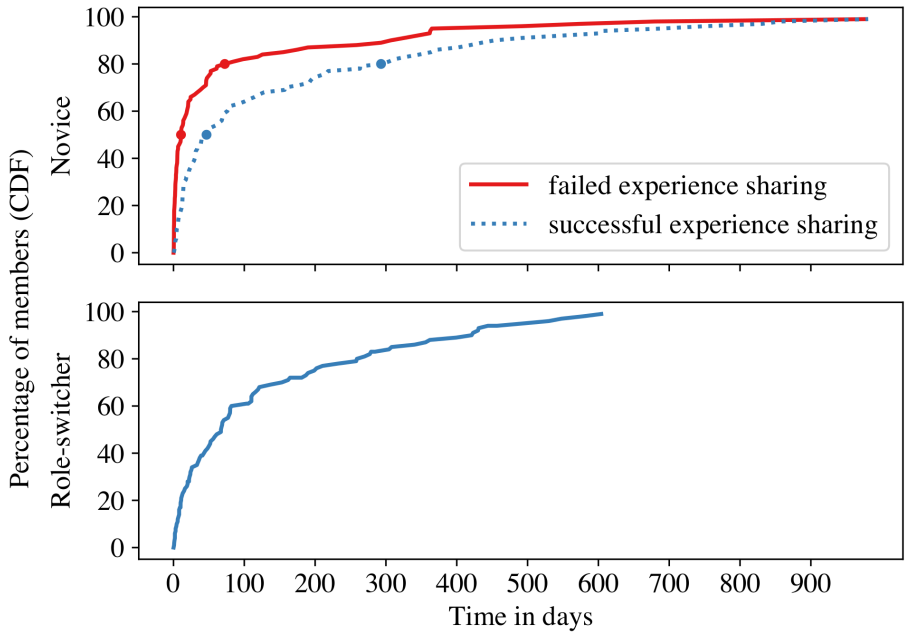


Figure 4.7: The growth of scammers over time while learning.

scamming experience since joining the forum and their first successful scamming experience. The top figure ("Novice") in Figure 4.7 shows the growth of novice scammers over the time of their experience.

I find out that 50% and 80% of these novice scammers posted their first failure within 10.6 and 72.4 days, posted their first success within 46.7 days and 293.1 days, and took an average of 16.7 and 99 days to success after their first failures, respectively. Note that scammers may share their experience later than the actual date, and failed experience are more likely to be shared because they are looking for help from sophisticated scammers.

I also discovered instances in which scam initiators become directly entangled in the underground economy by evolving into service providers. I identified 116 scam initiators who begin with posting "CAaaS Purchase Request" and later become service providers, starting "CAaaS Advertisement" threads. The bottom figure ("Role-

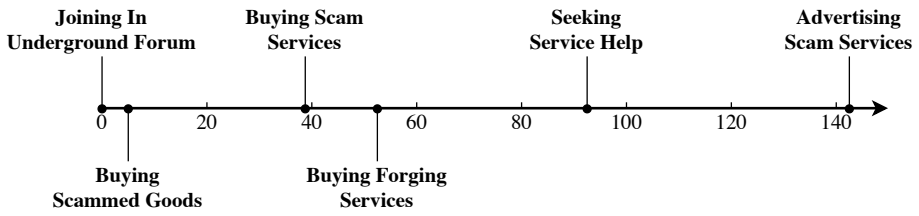


Figure 4.8: Timeline of the activities of a scammer who eventually switched roles and became a service provider.

switcher") in Figure 4.7 shows the growth of these 116 scammers over time: 50% of such service buyers take 67 days to start their business after first buying scam services, and 80% of them take 259 days.

To understand these role-switchers, I present a case study of one concession abuse scammer's journey from a novice to an expert. Figure 6.1 depicts a timeline of this scammer's activities. The scammer made a request for scam-obtained goods six days after engaging in several scam discussions, and they attempted to hire a service provider 33 days later. Then, after learning about the scam, the scammer started to defraud merchants directly: As evidence, they attempted to buy a forged image and sought help for scamming 51 days and 93 days after joining the underground forum, respectively. Ultimately, they became a service provider 142 days after joining the forum.

4.4.7 Financial Loss

It is impractical to directly estimate the financial loss caused by CAaaS solely based on the posts in underground forums because: (1) scam initiators do not frequently vouch for service providers, (2) while some shared screenshots show the refund amount, many of them redact the amount, and (3) some screenshots of proofs are reused by multiple service providers in their advertisements.

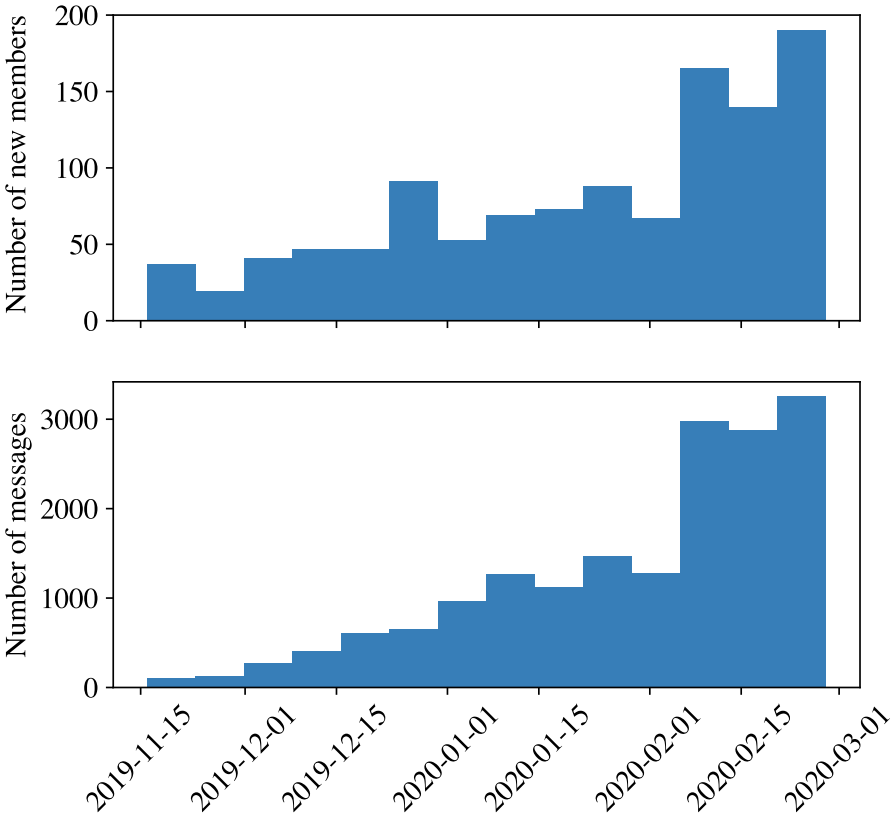


Figure 4.9: Member activities over the time in a telegram group of a scam provider.

However, I notice service providers prefer that scam initiators contact them through external messaging platforms (for privacy reasons), and 17.6% of providers manage groups on external platforms (such as Telegram) in which scammers can discuss concession abuse, making it possible to estimate the financial loss caused by individual service providers.

To this end, I joined the Telegram group of a well-known provider introduced in Section 4.4.2. I collected all public messages, pictures, and member profiles visible in this Telegram group. [3] Due to the popularity of CAaaS, the provider converted the group to a *supergroup* (maximum 100,000 members, from the default of 200) on

[3]My observational study underwent the IRB review and received approval.

Table 4.5: Discussions in telegram group.

Content Type	Discussions	Percentage of Messages
Scam Service-related	Service store, Service fee, Service questions, Service procedure	87.1%
Supporting	Seeking/Providing help	4.4%
Sharing	Scam experience sharing	2.5%
Group	Group rules;	4.2%
Others	Greetings, Group system messages, Group settings	1.8%

November 16, 2019. I thus collected data from November 16, 2019 to February 28, 2020.

I found that 1,076 members posted 17,898 messages within this period. To contextualize popularity trends, I count the number of new members and messages within a week-long sliding window. As shown in Figure 4.9, both the number of new members and messages has grown since the supergroup's creation.

To understand the discussions in the group, I randomly selected 2,000 messages for manual analysis. Table 4.5 shows the topics discussed in the Telegram group. 87.1% of the messages in the group were inquiries related the provider's service, 4.4% asked for help or offered scam-related support, 2.5% provided feedback, and the remainder were related to administrative or social matters.

It is worthy pointing out that the provider is the only service provider in the group. Members are only allowed to advertise their businesses or post links if approved by the provider: for example, certain vetted members offer cash-out services to monetize scam initiators' refunded e-gift cards. Therefore, all CAaaS related vouchers are for the provider's service.

Because the feedback from scam initiators often includes screenshots of refund confirmation, I collected all such screenshots in the group and extracted the text

using OCR [69]. I manually verified the results for merchant names. I identified 25 merchants from 227 screenshots, five of which were not listed in the provider's advertisements (see Table D.1). Hence, the provider is able to defraud other merchants as requested by initiators.

85 of these screenshots contained refund amounts (the remainder were redacted or incomplete). The provider helped refund the equivalent of $81,159.27 ($41,076.71, €17,130.4, and £7,393.29) over three months through scamming merchants in North America and Europe. Because not all screenshots had a refund amount, and not all scammers provide feedback, it is likely that the provider refunded a far higher amount.

Although I cannot definitively conclude the authenticity of all collected screenshots, I collaborated with two major (undisclosed) US merchants who confirmed several instances of successful scams. For example, one merchant confirmed that a $374.30 order was refunded to someone who claimed the goods were not delivered. The other confirmed that numerous high-value items were refunded, but would not provide specific details. This feedback from merchants, combined with the high level of activity in this scammer's Telegram group, allows us to conclude that CAaaS has a real financial impact on merchants.

4.4.8 Scammer Overlap

Next, I analyze the actions of CAaaS actors to see if they are involved in other cybercriminal activity (as evidenced by their observable actions on the underground forums in the dataset). As a recap for the analysis approach, I classified underground forum activities into Monetization, Hacking, Scam, and Other. I then further divided Scam into five primary types, based on the FBI Internet Fraud definition [32]. Finally, I label *all* the posts of CAaaS actors by these activities.

Table 4.6: The number of CAaaS scammers participating in other illicit activities (total CA actors: 49,720).

(a) Non-scam Activities

Content Category	Scammers	Ratio
Hacking	6,377	12.83%
Monetization	3,249	6.54%
Stolen Credential	12,827	25.80%

(b) Non-Concession Abuse Scams

Scam Type	Scammers	Ratio
Email Compromise	174	0.35%
Data Breach	150	0.30%
Denial of Service	253	0.51%
Phishing	67	0.14%
Ransomware	7	0.01%

Table 4.6 shows the number and ratio of CAaaS actors in non-scam activities and in non-CAaaS scams. I observe a reasonable proportion of CA scammers involved in non-scam activities, specifically Hacking (12.83%) and Stolen Credential (25.80%). These activities are closely related to CAaaS: For example, CAaaS may require compromised online merchant accounts, so it is likely that CAaaS actors are involved in the stolen credential activity.

However, few CAaaS actors are involved in other types of scams. This may be because concession abuse shares little in common with other scams and requires a different skillset.

4.5 The Success and Failure of CAaaS

In this section, I study the tricks that CAaaS scammers use to succeed and as well as cases in which they fail. To perform my analysis, I first leveraged the classifier that labels the successful and failed scam experience (§ 4.4.1) to randomly select 1,000 threads with each respective label. Then, I manually analyzed these threads and aggregated the various tricks and causes of success or failure. I include representative scammer quotes throughout this section.

4.5.1 Preparing for the Scam

Choosing merchants to target. CAaaS service providers typically prefer large merchants because they have robust customer service departments and are more willing to risk a financial loss in exchange for customer satisfaction. Such merchants are, therefore, more prone to being tricked into providing concessions; one scammer's advice was to *"just refund big companies, not small shops that can't afford the loss."* Moreover, many service providers caution *"DO NOT refund small businesses and individuals (such as on eBay)."*

Choosing accounts. Service providers prefer to carry out their scams using shopping accounts with a long order history and few refund or return claims, because such accounts closely resemble those of loyal customers. Sellers of compromised accounts emphasize these characteristics in their advertisements in underground forums: *"this is a great account to do the Amazon refund with, because it has a such a good history with no disputes or anything."*

Choosing orders. Because refund requests for recent orders appear routine to CSRs, such requests avoid unnecessary scrutiny and scammers, therefore, actively

seek compromised accounts with recent orders: *"I'm willing to pay for cracked amazon accounts with good recent orders yo hit me up."* Additionally, high-value orders are less desirable as they may trigger extra investigations. Therefore, many service providers set an order value limit for each merchant (see § 4.4.2).

4.5.2 Tricks During Scam Execution

Contact Method

There are three typical ways to contact a CSR: phone, live chat, or e-mail. Scammers prefer phone calls for two reasons: First, a phone call gives a CSR much less time to respond and, thus, decreases the chance that a CSR will sense unusual behavior. Second, speaking enables a service provider to effectively use social engineering to manipulate the conversation, through which the provider can influence a CSR's decision, or even *"lead the CSR into asking the questions the scammer wants."*

Deception Strategies

Expressing pity and urgency. Service providers fabricate stereotypical stories to evoke feelings of pity and urgency to influence CSRs' decisions. For example, a service provider could request a refund for *"an undelivered gift that was for her sick son's birthday."* Such a story attempts to make a CSR sympathetic with the goal of convincing the CSR to approve an immediate refund.

Being polite. CAaaS service providers usually behave politely when interacting with CSRs. They call CSRs by their names, express understanding of the mistakes, and show appreciation for their help: *"Fear or threats are* not *recommended for scamming"*, as a tutorial says *"Be somewhat charismatic and do not have an attitude with the reps."*

Expoliting legal regulations. Service providers may cite legal regulations to avoid returning the merchandise. For example, a CAaaS service provider may complain about a battery leakage in a purchased laptop and state that he cannot return it due to the *49 CFR 173.185* U.S. Lithium Battery Regulation. The service provider might also first agree to return the merchandise, and later state that they cannot do so because the shipping carrier rejected the shipment. If successful, the provider will receive a concession without returning the goods.

Exploiting incomplete communication between CSRs. Some CAaaS service providers call a merchant multiple times and lie to the latter CSR about an agreement with the previous CSR. For example, a scammer states in a tutorial that if they make two calls a few minutes apart, they are usually connected to a different CSR in the second call. They then lie to the second CSR that the previous call was dropped while the first CSR was processing the refund. In this way, they may receive a concession from the second CSR without needing to provide any concrete justification.

Reasons for Requesting a Refund

Package never delivered. Failure of a package to arrive is the most common fictitious claim used by scammers in concession abuse. Scammers usually contact the CSR a few days after the package is actually delivered, because some online merchants, such as Amazon, require the customer to contact 24 hours after delivery to open a claim. During the conversation, they follow the instructions of the CSR to build rapport and trust. For example, CSRs may ask if the scammer can ask their family members and neighbors or check both front and back doors. Scammers respond: *"Yeah, I asked my parents, they didn't see it. But I haven't checked with my neighbors. Can you wait a minute and I can ask them."* Then a few minutes later,

they tell the CSRs that the neighbors do not see it.

Empty box. Claiming an empty box is a popular and straightforward pretext to request a concession: *"I opened my package, there was nothing in it but some packaging paper, styrofoam and my invoice."* When CSRs receive such complaints in the absence of other risk factors, they have to issue the concession unless records show that the mailed package is obviously heavier than an empty box. Therefore, as long as the goods are not significantly bulky, these claims can be effective.

Missing item. Scammers may buy multiple goods in one order and lie that some items are missing. For example, one scammer shared, *"I ordered keyboard and mouse mat, then contacted amazon live chat. Said they were birthday gifts and only received the mouse mat, so I was given a refund for the keyboard."*

Wrong items. A service provider may claim that they were sent the wrong item, which is of similar weight but lesser value compared to the ordered item. If a return is requested, they will mail back a cheaper alternative and keep the actual item, as a scammer says *"I ordered a ralph lauren polo on zalando. Received the item, and returned an old polo and pretend I got the wrong item."*

Broken items. A service provider may claim that they received a broken item. For example, they may deliberately buy a specific item together with liquid goods and claim that the item was damaged due to a leak and cannot be returned: *"I received the box and it was leaking everywhere with this profusely smelling liquid and it looked like some of it had dried. It was doing this when you guys shipped it and I threw it immediately out to make sure my family didn't get hurt by this."*

Dealing with Return Requests

Standard shipping. This is the return policy adopted by most merchants, including Amazon. Per this policy, the merchant issues the concession only after receiving the return. If the targeted merchant uses this policy, the CAaaS service provider will send an empty box back and claim the returned item was stolen in shipment. In fact, many merchants will immediately issue the concession once the warehouse scans the box. Because shipping carriers typically measure the weight and size of the box, criminals often add junk totaling the same weight as the original item. Scammers may also deliberately seal the box poorly to help convince merchants that the box was opened in transit. The preparation of empty return shipments can be outsourced to *Boxing Service Agents*: criminals who specialize in such services.

Cross-shipping. Per this policy, merchants send out replacements once they see that the prepaid shipping label for the return is scanned by the carrier. Criminals adopt similar approaches to standard shipping, and the boxing service is widely used. Because criminals do not need to explain the empty box before receiving the concession, reshipping agents or drops are frequently employed to shield the scammer.

Advance replacement. Some companies have a policy under which they ship replacement products before the return shipping label is scanned, as long as their customers provide valid credit card information. In this case, the scammer will provide a Virtual Credit Card (VCC) purchased from VCC agents. One scammer advised: *"you will need a VCC with a dollar or two on it. Once the company you're SEing has your VCC, they will usually charge you the amount of the item once they ship it out. "*

4.5.3 Monetization Tactics

Scammers who use compromised accounts prefer refunds via e-gift cards over the original payment method because e-gift cards enable them to cash out. Additionally, if a scammer employs a reselling agent (§ 4.3.4) to monetize the refund, they would buy goods that can be shipped quickly. For example, the scammer will buy goods sold by (or at least fulfilled by) Amazon and select the fastest shipping option to minimize potential delays. Therefore, even if merchants notice the scam later and flag the e-gift card, scammers will have already spent the balance and monetized the refund.

To improve safety and convenience, many scam initiators leverage Bitcoin shopping websites (such *Purse.io*, which is frequently discussed by scammers in underground forums) to monetize their refunds without wasting time on advertising and sharing profits with individual resellers. Such a strategy work as follows: (1) a user posts a shopping list on the website, along with a discounted price they are willing to pay; (2) if the refund is similar to the cost of the shopping list, and the discounted price is acceptable, then the scam initiator will accept the order; (3) the user sends the discounted amount in Bitcoin to the website, and then the scam initiator starts to purchase the products and make the merchants ship them to the user; and (4) after the package is delivered, the website will release the Bitcoin to the scam initiator. In this way, scam initiators safely exchange their e-gift card balance to Bitcoin.

4.5.4 Failure Causes

Investigations. The most-discussed failure cases involve investigations by reshipping agents and merchants: (1) Legal reshipping companies that are abused by scammers may verify the receiver's identity and confirm the goods received with suppliers when

there is a high volume of packages sent to the same account. Also, such reshipping agents may contact merchants to verify if these goods can be shipped internationally if the reshipping address is not domestic.

(2) Merchants investigate cases of fraud using internal systems and external parties, such as shipping carriers. For example, a merchant could use *"geocode timestamp, information at the point of delivery, and package weight and condition"* to validate if the package is delivered.

Value of goods. High-value goods are more likely to trigger investigations, which is why service providers explicitly list price limits in their advertisements. If the goods are too valuable, a scammer may fail because of an automatic investigation.

Account activity. Unusual activity on the merchant accounts may attract scrutiny and subsequent investigation. Therefore, scammers seek to ensure that such accounts have a clear history of legitimate activity. I observed failures for three main reasons: (1) scammers attempt to use accounts having concession abuse claims, (2) scammers use an account linked to other accounts which were closed for abuse, and (3) account owners notice unusual account activity and report it.

Proof. Insufficient or unconvincing documentation is another key cause of failed scams. There are two types of failures related to proof: (1) scammers cannot provide the requested proof, which may happen if the CSR requests a video or other type of evidence that is difficult to forge (scammers also try to avoid interaction with law enforcement, so they prefer not to provide police reports), and (2) certain forged evidence fails a verification check. For example, scammers may make mistakes when forging documents; also, they may reuse certain types of proof, such as order receipt templates. Moreover, merchants may verify proof with other parties, which could

disrupt scammers.

Delivery. Scammers prefer to avoid risks, and some have therefore reported failures if they are asked to reveal their real identities or be seen in-person to receive the goods (i.e., when a signature or local post office pickup is needed).

Returning goods. Although scammers have tricks to avoid returning goods to merchants even though a return is required, they sometimes fail because either their return packages are inspected, or they would be forced to reveal their identities. For example, some merchants may either request that goods be returned to a local store, or they may send someone to pick them up, causing the scam to fail because the goods could then be inspected and the scammers would need to show their faces.

4.6 CAaaS Mitigation

I understand that merchants deploy numerous operational protocols to mitigate scams (e.g., issuing a refund only after receiving the returned goods and launching investigations when needed). However, concession abuse scammers seek to discover loopholes in these mitigations and work to bypass them. For example, Amazon was scammed out of €300,000 by a single person [37] who returned dirt multiple times; the scam likely succeeded due to the lack of inspection of returned goods or detection of compromised accounts, despite the fact that Amazon issues refunds only after receiving the returned goods.

4.6.1 Analysis Approach

I synthesize key merchant and ecosystem weaknesses that scammers abuse and propose possible mitigation solutions that address these weaknesses. I define criteria that determine the suitability of each mitigation, though I cannot effectively evaluate

Table 4.7: Overview of participants' attitudes toward my security protocols.

Security Protocol	Non-negative Attitude	Willingness to Continue Shopping
Investigation | CRS-OP (2)	93.2%	90.2%
Providing Proof | CRS-OP (3)	75.4%	68.6%
ID Verification | CRS-OP (5)	94.9%	93.6%
Local Return | MER-OP (3)	80.1%	86.0%
Separate Shipping | MER-OP (4)	94.5%	93.6%
PIN for E-gift Card | MER-OP (5)	92.8%	92.4%
Secondary Contact | MER-OP (6)	86.9%	87.7%

suitability without merchant data. I divide mitigations into thee different areas: Account Abuse Detection Principles (AADP), CSR Operational Protocols (CSR-OP), and Merchant Operational Protocols (MER-OP).

I then interviewed two large merchants to discuss the proposed mitigations. Although they confirmed to suffer from concession abuse scams, one merchant voiced concerns about *"an easy customer experience for legitimate customers."* Therefore, I also conducted a survey to more thoroughly evaluate defense solutions that could affect a customer's shopping experience. My survey consisted of two general sections and six scenario-based sections that aimed to gauge user attitudes toward such mitigations in practice. Although participants' attitudes in the survey and real-world behavior or preferences might differ, the results can still reveal their concerns and comfort levels with the proposed mitigations.

Table 4.7 shows an overview of the participants' attitudes towards my security protocols. The "Non-negative Attitude" column shows the percentage of participants who neither *mind* nor *strongly mind* the security protocol. Both studies (merchant interviews and user surveys) received approval from my IRB.

4.6.2 Account Abuse Detection Principles

Because criminals commonly leverage CAaaS to profit from compromised accounts, proactively detecting compromised accounts can prevent concession abuse at an early stage, potentially well before merchants are contacted by scammers. Furthermore, identifying accounts being accessed by scammers can help mitigate the damage caused by CAaaS.

Although general account fraud protection systems have been developed [16], such systems may not effectively prevent concession abuse on their own.

Therefore, I propose additional Account Abuse Detection Principles (AADP) to enhance such systems to protect against concession abuse scams.

AADP (1): Compromised account alerts. Scams involving compromised accounts may fail if the actual owner of the account is notified in a timely manner. Therefore, proactive monitoring and securing accounts sold in underground communities or in known data breaches can help prevent subsequent fraud [103].

AADP (2): Account history. Per my failure case analysis (Section 4.5.4), the use of accounts with abnormal historical activity is one of the primary reasons that a scam attempt might fail. Hence, the frequency of refund requests, especially for non-returnable claims, the dates of recent requests, and the number of attempts to refund the same order can determine the riskiness of an individual account. Moreover, if a compromised account is used in a scam, then it is difficult for attackers to ensure that the account has a very recent order (e.g., there is an average 7-day delay between credentials being phished and appearing in dumps [77]), so the date of the placed order can be a notable risk factor.

AADP (3): Account age. When unable to obtain compromised accounts, scammers may use newly created accounts to avoid placing their main accounts at risk while defrauding merchants. Therefore, a concession request from a new account with a short order history should be considered for investigation.

Furthermore, if a fresh account is linked to an account closed due to a scam, merchants should flag this new account and treat its concession claims as suspicious because they are likely tied to the same attacker.

AADP (4): Customer authentication. My analysis of chat logs in underground forums suggests that most answers to CSRs' questions can be found in the corresponding account profiles, such as verifying the customer's address. Therefore, technical authentication schemes can be used to mitigate attackers' use of compromised accounts, such as two-factor authentication for accessing account profile data or comparing the IP address and location of the user accessing the data with those of the accountholder.

AADP (5): E-gift card abuse detection. Detecting e-gift card abuse is another approach for finding compromised accounts that are being monetized via CAaaS. For example, if the time between the refund deposit into the e-gift card and the spending of the balance is short, and the purchased goods are shipped to a new address (especially to a known reshipping agent), then it is more likely that the account has been exploited by scammers.

4.6.3 CSR Operational Protocol

Deceiving CSRs into believing the pretexts is an essential step to successfully defrauding the merchant through concession abuse. To protect CSRs and mitigate such

scams, I propose additional CSR Operational Protocols (CSR-OP). Implementing some protocols (CSR-OP 2, 3, and 5) may influence customers' shopping experience, so I surveyed users and show their feedback in Table 4.7.

CSR-OP (1): Maintain clear customer service logs. Maintaining clear and complete customer service logs will help representatives better understand each request and more effectively synthesize any relevant historical context. In particular, the log should include any prior decisions made by other CSRs to avoid attackers' exploitation of gaps in information between CSRs, as discussed in Section 4.5.2.

CSR-OP (2): Investigations for high-value goods. CSRs should initiate investigations when customers request a concession without returning goods above a certain value threshold. This will help mitigate the loss of high-value items.

CSR-OP (3): Extra proof when original goods not returned. Merchants should require customers to provide extra proof if they are not going to return the original goods. Because scammers routinely forge proof, merchants should require proof that is difficult to forge, such as a video of the product with a handwritten reference number (which is currently known to be difficult to forge, as discussed in Section 4.5.4). Additionally, scammers wish to avoid law enforcement involvement, so requesting a police report can stop some scammers using the *"package not delivered"* pretext.

According to my user survey, this protocol had the most negative attitudes because participants think providing extra proof is inconvenient and that their moral character is being questioned. In general, 24.6% of participants either *mind* or *strongly mind* providing proof. However, I notice that if the proof does not require excessive effort, then 25.9% of participants who mind providing proof would still be willing to provide

it for valuable goods.

CSR-OP (4): Verification of proof. Merchants need to adequately verify the proof provided by the customer before issuing the requested refund or replacement. To balance the cost of the required information and inconvenience upon potentially innocent customers, merchants can use automatic verification first, which is fast yet might be less precise than a comprehensive manual verification. For example, if a customer provides a police report to claim a refund, then two possible automatic verification processes could be: (1) verifying that the same proof does not already exist in the merchant's database (because scammers often reuse proof shared in underground forums, discussed in Section 4.5.4), and (2) using image analysis techniques to check if the metadata of the photo matches the customer's profile, such as the city, and whether the photo was edited or otherwise tampered with. If any red flags are raised by the automated system, then a manual analysis could be performed, such as contacting the police station to verify the authenticity of a police report or asking the customer for additional evidence.

CSR-OP (5): Limiting changes to shipping address. CSRs should not change the shipping address for replacement items unless the new address is confirmed by accountholders through two-factor authentication. Verifying the identity of the customer is important because scammers frequently try to send items to reshipping agents or drops.

The primary concern about this protocol is that it is a time-wasting inconvenience. However, most survey participants expressed a willingness to use this protocol to secure their accounts.

4.6.4 Merchant Operation Protocol

To have comprehensive mitigations, I design a Merchant Operation Protocol (MER-OP) that can be used by merchants to help CSRs avoid being deceived. The MER-OP is designed to apply to general merchant operations, instead of a specific customer or request, as in the case of CSR-OP. I show participants' corresponding attitudes (MER-OP 3, 4, 5, 6) in Table 4.7.

MER-OP (1): Intelligence support for CSRs. Merchants should provide a dashboard of the caller and accountholder information side-by-side. In the meantime, a risk score indicating possible account abuse should be shown to help CSRs verify the authenticity of the caller. Moreover, CSRs operational protocols and other scam detection tools, such as image analysis tools, should be available in the dashboard. Also, the prior chat records of the same order should be shown to help CSRs have a comprehensive understanding of the claim. Therefore, this protocol also supports my AADP and CSR-OP recommendations.

MER-OP (2): Taking pictures during packaging. Taking pictures of the goods placed in the box during packaging is a straightforward yet effective approach for mitigating malicious *Missing item*, *Wrong item*, and *Empty box* refund claims. Such evidence would significantly reduce the believability of such claims compared to what is possible based solely on knowing the weight of the package, as discussed in Section 4.5.4.

MER-OP (3): Local returns for special items. Merchants can supplement online returns with an offline return policy to avoid return tactics used by scammers for high-value goods. In offline returns (i.e., processed in-person at the merchant's store

or with a partner retailer), goods can be directly inspected, and the accountholder's identity can be verified.

19.9% of participants either mind or strongly mind offline returns due to inconvenience (e.g., *"I am in a rural area and would have to drive a long ways."*) Upon deeper analysis, these participants may have misunderstood that they must return goods to merchants' local stores. Customers could bring the goods to a shipping carrier and let the staff there pack them (e.g., one participant said *"I already bring the item to UPS store when I return something, so there's no difference."*). Hence, I believe that the implementation of selective offline returns remains feasible.

MER-OP (4): Separating shipments of high-value goods. Placing high-value goods in separate packages, especially when multiple expensive items are included in a single order, helps defend against tactics such as *Missing items*, *Empty box*, and *Broken items*, as discussed in Section 4.5.2.

Merchants should consider participants' concerns, however, such as wasting packaging materials or increasing overall shipping costs.

MER-OP (5): Extra checks for e-gift card refunds. Merchants should ask customers to use enhanced authentication (e.g., a PIN) for their e-gift card payments to counter scammers' monetization methods discussed in Section 4.5.3.

Some participants said they would be annoyed if they had to remember more than one password, though most were satisfied with this protocol to secure their gift cards.

MER-OP (6): Securing contact information. Customers' contact information, such as email addresses and phone numbers, should be hidden in the system and differentiated from their publicly disclosed information to ensure accountholders can receive notifications about account activity even if the accounts are breached by

attackers. Alternatively, customers could provide a secondary email address or phone number for such notifications, which would be different from the email or username used to log in.

According to the survey, some participants do not want to provide a secondary notification contact because they neither have a secondary email address nor want to share their private email addresses. However, 81.8% of participants had a secondary email address that they could use as a secondary notification contact.

MER-OP (7): Collaboration with payment processors. Merchants should positively engage in any investigations or disputes from third parties, because scammers may attempt to bypass merchants' own anti-fraud systems by filing a fraudulent claim with a payment processor to get their refund or replacement. If ignored, such requests could also damage the merchants' reputation.

4.6.5 Survey of Customers' Attitudes to Proposed Defenses

To better understand the inconvenience that shoppers might experience from the aforementioned security measures, I surveyed users' attitudes and concerns using Amazon Mechanical Turk (MTurk) [66, 81].

Design. I categorized the defense schemes that involve customers and designed a survey with eight sections. In the first two survey sections, I collect: 1) participants' demographic information, and 2) general security experience related to online shopping. Six sections follow, each corresponding to a scenario with mitigations against concession abuse: 1) investigations and requests for proof following a claim, 2) identity verification for changing the shipping address, 3) local store returns for high-value goods, 4) separate shipments for high-value goods, 5) payment PIN for e-gift cards,

and 6) secondary contact information for security notifications. The six scenario-based survey questions can be found in Table C.1 in Appendix C. I measured user attitudes on five-point Likert scale ranging from *strongly not mind* (the user approves of the mitigation) to *strongly mind* (the user does not).

Participants. To obtain reliable survey data, I must recruit an appropriate set of participants. To this end, I conducted two pilot surveys: the first pilot was open to any MTurk worker from North America with at least 1,000 approved HITs, or a HIT approval rate higher than 95%, which indicates attentive participation [81]. The second pilot was open to Master Workers from North America (users recognized by Amazon for the reliability of their work) [39].

To analyze the response quality, I compare the participants' attitudes toward my security protocols with their short answers explaining their reasons. I found that Master Workers performed better than workers screened by approved HITs or HIT approval rates because 60% of responses in the first pilot were illogical or appeared rushed. For example, some participants in the first pilot indicated that they strongly minded one protocol while explaining that they did not mind in the short answer. We, therefore, recruited only Master Workers from North America in my main survey and paid $1 for participation.

In total, 247 workers participated in my survey. After removing low-quality responses and duplicate participants, I were left with the 236 responses upon which I based my analysis.

Results. The detailed survey results can be found in Appendix C. Table C.2 and Table C.3 show the demographics and the general security experience of my participants, respectively. Table C.5 summarizes participants' attitudes toward the security

protocols. In Table C.4, I show representative short answers to highlight participants' key concerns about different scam prevention approaches.

4.7 Limitations

Because CAaaS is an emerging attack technique and an underground service industry, it is challenging to study. This section discusses these challenges and encourages future researchers to investigate these aspects of the underground economy.

Ground truth from merchants. In my conversations with merchants, I found that they are reluctant to share ground truth data about attacks that they experienced or to closely collaborate on the development and evaluation of preventative mitigations. Thus, I based my study on crawled and leaked data from underground forums, relying on strategies, successes, and failures self-reported by cybercriminals in communications with each other.

Of course, there is no guarantee of the veracity of such information or the real-world effectiveness of my suggested intervention protocols. However, I provide the first look into the supply chain of CAaaS. Additionally, I acknowledge that participants' attitudes in the survey and real-world preferences might differ, which can be further studied in the future.

Ground truth from cybercriminals. Cybercriminals are, understandably, a secretive group, which increases the difficulty in studying their activity. my forum data is an approximation of the behavior of cybercriminals, and its veracity is impossible to quantify. While I could add additional underground forums to my dataset (anecdotally, recent observation of underground forums revealed an increase in subforums dedicated specifically to concession abuse), the data on which I base this work

presents a clear picture of the structure and impact of CAaaS.

I cannot be certain in my estimate of the difficulty of learning how to perform concession abuse scams. Because my time interval analysis is based on scammers' post timestamps, and scammers may not immediately (or always) share their experiences, I can only make estimates of these intervals.

Similarly, without ground truth from retailers, it is impossible to verify the actual financial loss caused by the scam. I hope that as CAaaS continues to impact merchants financially, they will evaluate and implement potential mitigations.

4.8 Related Work

Underground forum analysis. Underground forums are used as rendezvous locations for cybercriminals who want to exchange information and sell illicit products and services [115]. Our research builds on several techniques used in prior work, including studies of the economics of cybercrime based on criminals' discussions in underground forums [25, 29] and studies that analyze forum user structure and interactions [4, 68]. Motoyama et al. evaluated how inherent distrust among criminals in underground communities affects their mutual interactions [71]. Afroz et al. tried to identify anonymous forum posters by analyzing their writing styles [5]. Also, Zhao et al. proposed an approach for mining evidence in underground forums to expose the social dynamics among adversaries involved in Internet-based attacks [114].

Specific cybercrime services in underground forums were also studied. Hao et al. studied reshipping services, which were found to contribute as much as $1.8 billion to overall reshipping scam revenue [38]. Researchers have analyzed phishing kits and services in underground forums [75, 76, 94, 113] to reveal phishing service costs, operational steps, actors, and reasons for profitability. Karami et al. analyzed DDoS-as-Service in underground forums to show the internal operations, usage patterns,

and attack infrastructure [49, 50].

Social engineering. Scammers use social engineering tactics to manipulate victims into sharing confidential information or performing specific actions. Atkins et al. and Ferreira et al. studied the persuasion techniques used in social engineering [8, 33]. By analyzing 74 scenarios, Bullée et al. showed which persuasion principles are most effective for social engineering attacks [17]. Irani et al. studied reverse social engineering attacks that deceived people to visit malicious websites by abusing social networks, without the need for direct contact with victims [44]. Researchers also conducted studies of web-based social engineering attacks that trick users into downloading malicious software [48, 72].

4.9 Conclusion

In this chapter, I identify and describe CAaaS, an emerging scam threat fueled by the underground economy. Through manual and automated analysis of crawled and leaked data from four underground forums, I describe different types of actors involved in CAaaS, the anatomy of the scam and service itself, tricks used to increase the likelihood of success, and the potential victims (as advertised by actual scammers themselves). My analysis shows that CAaaS impacts numerous online merchants globally and is becoming more prevalent in underground forums. Moreover, given the wealth of resources and services available in these forums, 50% of novices learn how to successfully defraud merchants within 47 days or less.

Additionally, I analyzed attackers' tactics and failure cases to identify potential limitations, and I proposed several defenses—which could be adopted directly by merchants and payment processors—to detect and mitigate instances of this scam. Moreover, I surveyed users to evaluate their attitudes and understand their concerns

toward the proposed mitigations.

While studying the scam service in underground forums, I notice criminals become more active in exploiting human vulnerabilities to conduct various attacks in clearnet as well, and the phishing attack is one of the most prevalent cybercrimes. It has been discovered that understanding human nature is an effective method against these human-centric attacks, and phishing awareness trainings are proven to decrease the rate of clicking phishing emails. However, the rate of reporting phishing attacks is unexpectedly low, leaving phishing websites with hours of additional active time before being detected. To this end, I will present my ongoing work in Chapter 5 in which I plan to a comprehensive evaluation of the phishing reporting ecosystem to identify the critical challenges while reporting phishing attacks.

Chapter 5

PLANNED: AN ANALYSIS OF THE PHISHING REPORTING ECOSYSTEM

5.1 Introduction

The phishing attack has become one of the most prevalent cyber attcks [107, 113] that exploits human-centric vulnerabilities [111] to lure victims into disclosing their sensitive information (e.g., personal identity information, account credentials) by leveraging social engineering [14]. According to the FBI, the phishing attack is a prominent cybercrime type because of the most significant number of complaints (241,342 complaints, an increase of 110.4% from 2019) received in 2020 compared with other crime types [31].

To empower users' ability to defend against phishing attacks, in addition to proposing and developing various anti-phishing technical solutions [3, 62, 101] to combat the cat-and-mouse game with the phishers, researchers have been investing much effort in educating the weakest link in phishing, humans, which has been identified as an effective strategy to defend against social engineering attacks [2]

Although the phishing awareness training is proven to decrease the rate of clicking phishing emails [21], the rate of reporting phishing attacks is unexpectedly low: 93% of employees didn't report the phishing emails in the phishing test [105], and 95% of phishing emails were not reported even within one week after the anti-phishing awareness training [106]. Considering reporting phishing attacks also can facilitate more phishing sites getting blacklisted earlier and deter further victimization by the same phishing sites [77, 80], it is imperative to understand the reasons behind the low rate of reporting phishing attacks, which has been largely overlooked. Furthermore, I

notice that another two forms of phishing attacks, smishing and vishing, are becoming more common nowadays because 84% and 83% of organizations faced smishing and vishing attacks in 2019, respectivelly [83]. However, little research has been conducted to study the challenges of dealing with such emerging phishing attacks within the existing phishing reporting ecosystem.

To this end, I will make a compreheisve evaluation on the phishing reporting ecosystem to identify the critical challenges people face and concerns they have when reporting smishing, vishing, and phishing email attacks. I plan to conduct three experiments to investigate the ecosystem from three perspectives to gain a better understanding of: (1) what the reporting ecosystem offers individuals seeking to report phishing attacks, (2) what the actual experience is in preparing to report a phishing attack, and (3) what happens to the phishing sites after being reported.

Chapter 6

COMPLETED AND PLANNED WORK

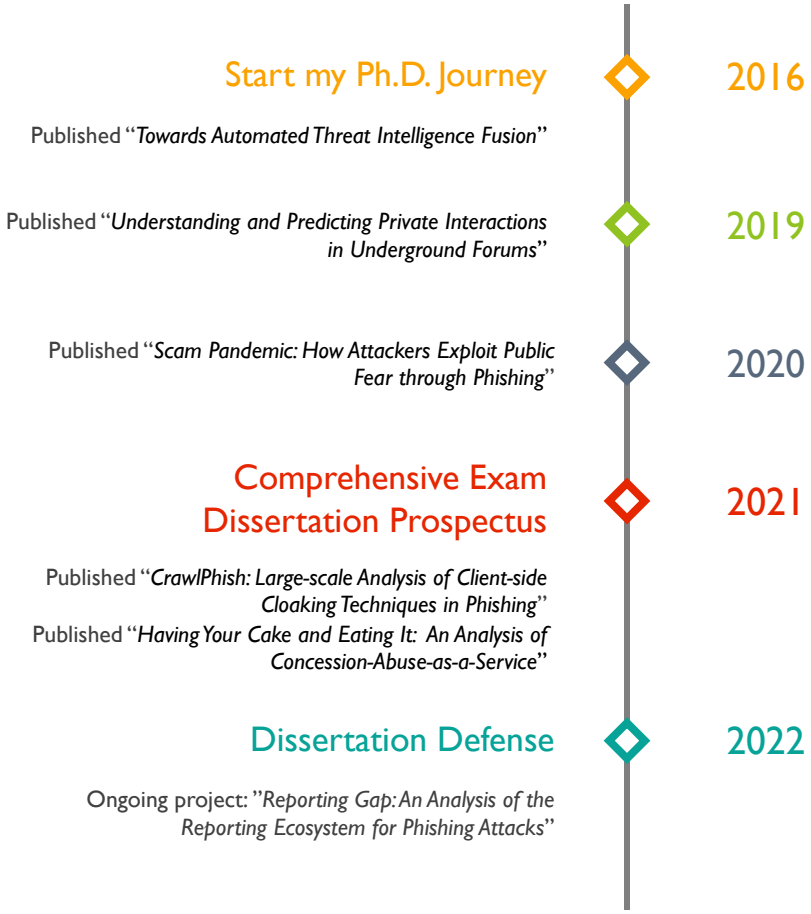


Figure 6.1: The timeline of my Ph.D. journey.

Figure 6.1 shows the timeline of my Ph.D. journey. I started my Ph.D. career in 2016, and passed the comprehensive exam in April 2021. Also, I plan to schedule my dissertation prospectus defense in Dec 2021 and defense my dissertation in April 2022.

Completed Work. I have completed the following work proposed for my dissertation.

[1] ***Having Your Cake and Eating it: An Analysis of Concession-Abuse-as-a-Service.*** It has been accepted and published in *Proceedings of the USENIX Security Symposium (USENIX)*, 2021.

[2] *CrawlPhish: Large-scale Analysis of Client-side Cloaking Techniques in Phishing.* It has been accepted and published in *Proceedings of the IEEE Symposium on Security and Privacy (Oakland)*, 2021.

[3] *Scam Pandemic: How Attackers Exploit Public Fear through Phishing.* It has been accepted and published in *Proceedings of the Symposium on Electronic Crime Research (eCrime)*, 2020.

[4] ***Understanding and Detecting Private Interactions in Underground Forums.*** It has been accepted and published in *Proceedings of the ACM Conference on Data and Application Security and Privacy (CODASPY)*, 2019.

[5] *Towards Automated Threat Intelligence Fusion.* It has been accepted and published in *Proceedings of the IEEE International Conference on Collaboration and Internet Computing (CIC)*, 2016 .

Planned Work For the planned work discussed in Chapter 5, I have completed the preliminary experimental design of the first experiment.

Throughout the next phase of my PhD career, I will continue working on experiments and conduct quantitative & qualitative analysis to understand: (1) what the challenges in security advice and actual channels are for reporting three forms of phishing attacks, (2) what factors in participants' backgrounds may influence their ability to locate reporting channels for different types of phishing attacks, (3) what participants' concerns and attitudes are while preparing for reporting phishing attacks, (4) what difficulties participants encounter when reporting phishing attacks, (5) what happens to reported phishing websites, and (6) what feedback the reporters will receive after reporting attacks.

REFERENCES

[1] "Digital Around the World", URL https://datareportal.com/global-digital-overview (2021).

[2] Abass, I. A. M. *et al.*, "Social Engineering Threat and Defense: A Literature Survey", Journal of Information Security **9**, 04, 257 (2018).

[3] Abdelnabi, S., K. Krombholz and M. Fritz, "Visualphishnet: Zero-day phishing website detection by visual similarity", in "Proceedings of the ACM Conference on Computer and Communications Security (CCS)", (2020).

[4] Afroz, S., V. Garg, D. McCoy and R. Greenstadt, "Honor among thieves: A common's analysis of cybercrime economies", in "eCrime Researchers Summit (eCRS)", (2013).

[5] Afroz, S., A. C. Islam, A. Stolerman, R. Greenstadt and D. McCoy, "Doppelgänger Finder: Taking Stylometry To The Underground", in "Proceedings of the IEEE Symposium on Security and Privacy", (2014).

[6] Aggarwal, A. and P. Kumaraguru, "What they do in shadows: Twitter underground follower market", in "Proceedings of the IEEE Annual Conference on Privacy, Security and Trust (PST)", (2015).

[7] Al Hasan, M. and M. J. Zaki, "A survey of link prediction in social networks", in "Social network data analytics", (2011).

[8] Atkins, B. and W. Huang, "A study of social engineering in online frauds", Open Journal of Social Sciences **1**, 03, 23 (2013).

[9] Awheda, M. D. and H. M. Schwartz, "A fuzzy reinforcement learning algorithm using a predictor for pursuit-evasion games", in "Proceedings of the IEEE International Systems Conference (SysCon)", (2016).

[10] Benevenuto, F., T. Rodrigues, M. Cha and V. Almeida, "Characterizing user behavior in online social networks", in "Proceedings of the ACM SIGCOMM Conference on Internet Measurement (IMC)", (2009).

[11] Benjamin, V. and H. Chen, "Securing cyberspace: Identifying key actors in hacker communities", in "Proceedings of the IEEE International Conference on Intelligence and Security Informatics (ISI)", (2012).

[12] Bhalerao, R., M. Aliapoulios, I. Shumailov, S. Afroz, D. McCoy, K. Levchenko and V. Paxson, "Mapping the underground: Towards automatic discovery of cybercrime supply chains", arXiv preprint arXiv:1812.00381 (2018).

[13] Bhd., H. D. S., "Identify Geographical Location by IP Address", URL https://www.ip2location.com/, (Last accessed Nov 9, 2019) (2019).

[14] Bijmans, H., T. Booij, A. Schwedersky, A. Nedgabat and R. van Wegberg, "Catching Phishers By Their Bait: Investigating the Dutch Phishing Landscape through Phishing Kit Detection", in "Proceedings of the USENIX Security Symposium (USENIX)", (2021).

[15] Bird, S., E. Klein and E. Loper, *Natural language processing with Python: analyzing text with the natural language toolkit* (O'Reilly Media, Inc., 2009).

[16] Brown, M. W., J. H. McIntyre, M. A. Paolini, J. M. Weaver and S. L. Winters, "Providing account usage fraud protection", US Patent 7,149,296 (2006).

[17] Bullée, J.-W. H., L. Montoya, W. Pieters, M. Junger and P. Hartel, "On the anatomy of social engineering attacks: A literature-based dissection of successful attacks", Journal of investigative psychology and offender profiling **15**, 1, 20–45 (2018).

[18] Burke, M. and R. E. Kraut, "Growing closer on facebook: changes in tie strength through social network site use", in "Proceedings of the ACM SIGCHI Conference on Human Factors in Computing Systems (CHI)", (2014).

[19] Caballero, J., C. Grier, C. Kreibich and V. Paxson, "Measuring pay-per-install: the commoditization of malware distribution.", in "Proceedings of the USENIX Security Symposium (USENIX)", (2011).

[20] Cao, Y. and J. Yang, "Towards making systems forget with machine unlearning", in "Proceedings of the IEEE Symposium on Security and Privacy", (2015).

[21] Carella, A., M. Kotsoev and T. M. Truta, "Impact of security awareness training on phishing click-through rates", in "Proceedings of the IEEE International Conference on Big Data (BigData)", (2017).

[22] Chawla, N. V., "Data mining for imbalanced datasets: An overview", in "Data mining and knowledge discovery handbook", (2009).

[23] Chen, H., X. Li and Z. Huang, "Link prediction approach to collaborative filtering", in "Proceedings of the ACM/IEEE-CS Joint Conference on Digital Libraries (JCDL)", (2005).

[24] Chen, L., Y. Ye and T. Bourlai, "Adversarial Machine Learning in Malware Detection: Arms Race between Evasion Attack and Defense", in "Proceedings of the IEEE European Intelligence and Security Informatics Conference (EISIC)", (2017).

[25] Christin, N., "Traveling the silk road: A measurement analysis of a large anonymous online marketplace", in "Proceedings of the International World Wide Web Conference (WWW)", (2013).

[26] Clauset, A., C. Moore and M. E. Newman, "Hierarchical structure and the prediction of missing links in networks", Nature (2008).

[27] Diesner, J. and K. M. Carley, "Revealing social structure from texts: meta-matrix text analysis as a novel method for network text analysis", in "Causal mapping for research in information technology", (2005).

[28] Dong, Y., J. Tang, S. Wu, J. Tian, N. V. Chawla, J. Rao and H. Cao, "Link prediction and recommendation across heterogeneous social networks", in "Proceedings of the IEEE International Conference on Data Mining (ICDM)", (2012).

[29] Durrett, G., J. K. Kummerfeld, T. Berg-Kirkpatrick, R. S. Portnoff, S. Afroz, D. McCoy, K. Levchenko and V. Paxson, "Identifying products in online cybercrime marketplaces: A dataset for fine-grained domain adaptation", arXiv preprint arXiv:1708.09609 (2017).

[30] Ellison, N. B., C. Steinfield and C. Lampe, "The benefits of facebook "friends:" social capital and college students' use of online social network sites", Journal of computer-mediated communication (2007).

[31] FBI, "2020 Internet Crime Report", URL `https://www.ic3.gov/Media/PDF/AnnualReport/2020_IC3Report.pdf` (2020).

[32] FBI, "Internet fraud", URL `https://www.fbi.gov/scams-and-safety/common-scams-and-crimes/internet-fraud`, (Last accessed Jun 18, 2020) (2021).

[33] Ferreira, A., L. Coventry and G. Lenzini, "Principles of persuasion in social engineering and their use in phishing", in "International Conference on Human Aspects of Information Security, Privacy, and Trust", pp. 36–47 (Springer, 2015).

[34] Finkel, J. R., T. Grenager and C. Manning, "Incorporating non-local information into information extraction systems by gibbs sampling", in "Proceedings of Association for Computational Linguistics (ACL)", (2005).

[35] Franklin, J., A. Perrig, V. Paxson and S. Savage, "An inquiry into the nature and causes of the wealth of internet miscreants.", in "Proceedings of the ACM Conference on Computer and Communications Security (CCS)", (2007).

[36] Fuentes, M. R., "WannaCry Ransomware Sold in the Middle Eastern and North African Underground", URL `https://blog.trendmicro.com/trendlabs-security-intelligence/wannacry-ransomware-middle-eastern-north-african-underground/` (2017).

[37] Hagen, I. V., "22-year-old allegedly scammed amazon out of $370k with return shipments filled with dirt", URL `https://www.newsweek.com/22-year-old-allegedly-scammed-amazon-out-370k-return-shipments-filled-dirt-1452` (Last accessed Nov 9, 2019) (2019).

[38] Hao, S., K. Borgolte, N. Nikiforakis, G. Stringhini, M. Egele, M. Eubanks, B. Krebs and G. Vigna, "Drops for stuff: An analysis of reshipping mule scams", in "Proceedings of the ACM Conference on Computer and Communications Security (CCS)", (2015).

[39] Harbach, M., S. Fahl and M. Smith, "Who's afraid of which bad wolf? a survey of it security risk awareness", in "Proceedings of the IEEE Computer Security Foundations Symposium (CSF)", (2014).

[40] Holz, T., M. Engelberth and F. Freiling, "Learning more about the underground economy: A case-study of keyloggers and dropzones", in "Proceedings of the European Symposium on Research in Computer Security (ESORICS)", (2009).

[41] Hong, J., "The State of Phishing Attacks", Communications of the ACM **55**, 1, 74–81 (2012).

[42] Hu, X., L. Tang, J. Tang and H. Liu, "Exploiting social relations for sentiment analysis in microblogging", in "Proceedings of the ACM International Conference on Web Search and Data Mining (WSDM)", (2013).

[43] Hutchings, A. and T. J. Holt, "A crime script analysis of the online stolen data market", British Journal of Criminology (2015).

[44] Irani, D., M. Balduzzi, D. Balzarotti, E. Kirda and C. Pu, "Reverse social engineering attacks in online social networks", in "International Conference on Detection of Intrusions and Malware, and Vulnerability Assessment", pp. 55–74 (Springer, 2011).

[45] Isah, H., D. Neagu and P. Trundle, "Bipartite network model for inferring hidden ties in crime data", in "Proceedings of the IEEE/ACM International Conference on Advances in Social Networks Analysis and Mining (ASONAM)", (2015).

[46] Jankowski, P. A. and C.-L. Yen, "Return fraud protection system", US Patent 8,942,990 (2015).

[47] Jones, K. S., M. E. Armstrong, M. K. Tornblad and A. S. Namin, "How social engineers use persuasion principles during vishing attacks", Information & Computer Security (2020).

[48] Junger, M., L. Montoya and F.-J. Overink, "Priming and warnings are not effective to prevent social engineering attacks", Computers in human behavior **66**, 75–87 (2017).

[49] Karami, M. and D. McCoy, "Understanding the emerging threat of ddos-as-a-service", in "Presented as part of the 6th USENIX Workshop on Large-Scale Exploits and Emergent Threats", (2013).

[50] Karami, M., Y. Park and D. McCoy, "Stress testing the booters: Understanding and undermining the business of ddos services", in "Proceedings of the International World Wide Web Conference (WWW)", (2016).

[51] Khan, A. Z., M. Atique and V. Thakare, "Combining lexicon-based and learning-based methods for twitter sentiment analysis", International Journal of Electronics, Communication and Soft Computing Science & Engineering (IJECSCSE) (2015).

[52] Kigerl, A., "Profiling cybercriminals: Topic model clustering of carding forum member comment histories", Social Science Computer Review **36**, 5, 591–609 (2018).

[53] Krombholz, K., H. Hobel, M. Huber and E. Weippl, "Advanced social engineering attacks", Journal of Information Security and applications **22**, 113–122 (2015).

[54] Kwak, H., C. Lee, H. Park and S. Moon, "What is twitter, a social network or a news media?", in "Proceedings of the International World Wide Web Conference (WWW)", (2010).

[55] Kwon, B. J., J. Mondal, J. Jang, L. Bilge and T. Dumitraş, "The dropper effect: Insights into malware distribution with downloader graph analytics", in "Proceedings of the ACM Conference on Computer and Communications Security (CCS)", (2015).

[56] Lampe, C. A., N. Ellison and C. Steinfield, "A familiar face (book): profile elements as signals in an online social network", in "Proceedings of the ACM SIGCHI Conference on Human Factors in Computing Systems (CHI)", (2007).

[57] Latto, N., "What is WannaCry", URL `https://www.avast.com/c-wannacry` (2021).

[58] Lewis, J., "Economic Impact of Cybercrime – No Slowing Down", Tech. rep. (2018).

[59] Liben-Nowell, D. and J. Kleinberg, "The link-prediction problem for social networks", journal of the Association for Information Science and Technology (2007).

[60] Lim, K. W., C. Chen and W. Buntine, "Twitter-network topic model: A full bayesian treatment for social network and text modeling", arXiv preprint arXiv:1609.06791 (2016).

[61] Lin, K.-Y. and H.-P. Lu, "Why people use social networking sites: An empirical study integrating network externalities and motivation theory", Computers in human behavior (2011).

[62] Lin, Y., R. Liu, D. M. Divakaran, J. Y. Ng, Q. Z. Chan, Y. Lu, Y. Si, F. Zhang and J. S. Dong, "Phishpedia: A Hybrid Deep Learning Based Approach to Visually Identify Phishing Webpages", in "Proceedings of the USENIX Security Symposium (USENIX)", (2021).

[63] Liu, B. and L. Zhang, "A survey of opinion mining and sentiment analysis", in "Mining text data", (2012).

[64] Lo, C., D. Frankowski and J. Leskovec, "Understanding behaviors that lead to purchasing: A case study of pinterest", in "Proceedings of the ACM SIGKDD International Conference on Knowledge Discovery and Data Mining (KDD)", (2016).

[65] McCallum, A., A. Corrada-Emmanuel and X. Wang, "Topic and role discovery in social networks.", in "Proceedings of the International Joint Conference on Artificial Intelligence (IJCAI)", (2005).

[66] Melicher, W., B. Ur, S. M. Segreti, S. Komanduri, L. Bauer, N. Christin and L. F. Cranor, "Fast, lean, and accurate: Modeling password guessability using neural networks", in "Proceedings of the USENIX Security Symposium (USENIX)", (2016).

[67] Mi, X., X. Feng, X. Liao, B. Liu, X. Wang, F. Qian, Z. Li, S. Alrwais, L. Sun and Y. Liu, "Resident evil: Understanding residential ip proxy as a dark service", in "Proceedings of the IEEE Symposium on Security and Privacy", (2019).

[68] Modi, A., Z. Sun, A. Panwar, T. Khairnar, Z. Zhao, A. Doupé, G.-J. Ahn and P. Black, "Towards automated threat intelligence fusion", in "Proceedings of the IEEE International Conference on Collaboration and Internet Computing (CIC)", (2016).

[69] Mori, S., H. Nishida and H. Yamada, *Optical character recognition* (John Wiley & Sons, Inc., 1999).

[70] Morris, M. R., J. Teevan and K. Panovich, "What do people ask their social networks, and why?: a survey study of status message q&a behavior", in "Proceedings of the ACM SIGCHI Conference on Human Factors in Computing Systems (CHI)", (2010).

[71] Motoyama, M., D. McCoy, K. Levchenko, S. Savage and G. M. Voelker, "An analysis of underground forums", in "Proceedings of the ACM SIGCOMM Conference on Internet Measurement (IMC)", (2011).

[72] Nelms, T., R. Perdisci, M. Antonakakis and M. Ahamad, "Towards measuring and mitigating social engineering software download attacks.", in "Proceedings of the USENIX Security Symposium (USENIX)", pp. 773–789 (2016).

[73] Nguyen, M.-T. and E.-P. Lim, "On predicting religion labels in microblogging networks", in "Proceedings of the ACM SIGIR Conference on Research & Development in Information Retrieval (SIGIR)", (2014).

[74] O'Connor, B., R. Balasubramanyan, B. R. Routledge, N. A. Smith *et al.*, "From tweets to polls: Linking text sentiment to public opinion time series.", in "Proceedings of the International AAAI Conference on Web and Social Media (ICWSM)", (2010).

[75] Oest, A., "Leveraging scalable data analysis to proactively bolster the anti-phishing ecosystem", Arizona State University (2020).

[76] Oest, A., Y. Safaei, A. Doupé, G.-J. Ahn, B. Wardman and K. Tyers, "Phishfarm: A scalable framework for measuring the effectiveness of evasion techniques against browser phishing blacklists", in "Proceedings of the IEEE Symposium on Security and Privacy", (2019).

[77] Oest, A., P. Zhang, B. Wardman, E. Nunes, J. Burgis, A. Zand, K. Thomas, A. Doupé and G.-J. Ahn, "Sunrise to sunset: Analyzing the end-to-end life cycle and effectiveness of phishing attacks at scale", in "Proceedings of the USENIX Security Symposium (USENIX)", (2020).

[78] Osborne, C., "Nulled.io hacking forum data breach exposes attackers in the shadows", URL `https://www.zdnet.com/article/nulled-oi-hacking-forum-data-breach-exposes-attackers-in-the-shadows/`, (Last accessed Jun 1, 2020) (2016).

[79] Pastrana, S., A. Hutchings, A. Caines and P. Buttery, "Characterizing Eve: Analysing Cybercrime Actors in a Large Underground Forum", in "Proceedings of the International Symposium on Research in Attacks, Intrusions and Defenses (RAID)", (2018).

[80] PhishMe, "Phishing Defense Guide 2017", Tech. rep. (2017).

[81] Plane, A. C., E. M. Redmiles, M. L. Mazurek and M. C. Tschantz, "Exploring user perceptions of discrimination in online targeted advertising", in "Proceedings of the USENIX Security Symposium (USENIX)", (2017).

[82] Poese, I., S. Uhlig, M. A. Kaafar, B. Donnet and B. Gueye, "Ip geolocation databases: Unreliable?", ACM SIGCOMM Computer Communication Review (2011).

[83] Proofpoint, "2020 State of the Phish: An in-depth look at user awareness, vulnerability and resilience", Tech. rep. (2020).

[84] Qin, T. and J. K. Burgoon, "An Investigation of Heuristics of Human Judgment in Detecting Deception and Potential Implications in Countering Social Engineering", in "Proceedings of the IEEE International Conference on Intelligence and Security Informatics (ISI)", (2007).

[85] Radianti, J., "A study of a social behavior inside the online black markets", in "Proceedings of the International Conference on Emerging Security Information, Systems and Technologies (SECURWARE)", (2010).

[86] Register, T., "British booster bandit walks free after pleading guilty to malware sales", URL `https://www.theregister.co.uk/2016/04/11/grant_manser_sold_50k_in_stressers_sidesteps_slammer/`, (Last accessed Aug 24, 2017) (2016).

[87] Ross, C., E. S. Orr, M. Sisic, J. M. Arseneault, M. G. Simmering and R. R. Orr, "Personality and motivations associated with facebook use", Computers in human behavior (2009).

[88] Samtani, S., R. Chinn and H. Chen, "Exploring hacker assets in underground forums", in "Proceedings of the IEEE International Conference on Intelligence and Security Informatics (ISI)", (2015).

[89] Scellato, S., A. Noulas and C. Mascolo, "Exploiting place features in link prediction on location-based social networks", in "Proceedings of the ACM SIGKDD International Conference on Knowledge Discovery and Data Mining (KDD)", (2011).

[90] Seidman, G., "Self-presentation and belonging on facebook: How personality influences social media use and motivations", Personality and Individual Differences (2013).

[91] Shah, K., T. Shenvi, K. Desai, R. Asrani and V. Jain, "Phishing: An evolving threat", International Journal of Students' Research in Technology & Management **3**, 1, 216–222 (2015).

[92] Shahriar, H., T. Klintic, V. Clincy *et al.*, "Mobile Phishing Attacks and Mitigation Techniques", Journal of Information Security **6**, 03, 206 (2015).

[93] Shulman, A., "The underground credentials market", Computer Fraud & Security **2010**, 3, 5–8 (2010).

[94] Sood, A. K. and R. J. Enbody, "Crimeware-as-a-service: a survey of commoditized crimeware in the underground market", International Journal of Critical Infrastructure Protection (2013).

[95] Speights, D. and M. Hilinski, "Return fraud and abuse: How to protect profits", Retailing Issues Letter **17**, 1, 1–6 (2005).

[96] Stone-Gross, B., T. Holz, G. Stringhini and G. Vigna, "The underground economy of spam: A botmaster's perspective of coordinating large-scale spam campaigns", LEET (2011).

[97] Stringhini, G., G. Wang, M. Egele, C. Kruegel, G. Vigna, H. Zheng and B. Y. Zhao, "Follow the green: growth and dynamics in twitter follower markets", in "Proceedings of the ACM SIGCOMM Conference on Internet Measurement (IMC)", (2013).

[98] Sun, A., E.-P. Lim and Y. Liu, "On strategies for imbalanced text classification using svm: A comparative study", Decision Support Systems (2009).

[99] Sun, Z., C. E. Rubio-Medrano, Z. Zhao, T. Bao, A. Doupé and G.-J. Ahn, "Understanding and Detecting Private Interactions in Underground Forums", in "Proceedings of the ACM Conference on Data and Application Security and Privacy (CODASPY)", (2019).

[100] Sundaresan, S., D. McCoy, S. Afroz and V. Paxson, "Profiling underground merchants based on network behavior", in "Proceedings of the IEEE Symposium on Electronic Crime Research (eCrime)", (2016).

[101] Thomas, K., C. Grier, J. Ma, V. Paxson and D. Song, "Design and evaluation of a real-time url spam filtering service", in "Proceedings of the IEEE Symposium on Security and Privacy", (2011).

[102] Thomas, K., F. Li, A. Zand, J. Barrett, J. Ranieri, L. Invernizzi, Y. Markov, O. Comanescu, V. Eranti, A. Moscicki *et al.*, "Data breaches, phishing, or malware? understanding the risks of stolen credentials", in "Proceedings of the ACM Conference on Computer and Communications Security (CCS)", (2017).

[103] Thomas, K., F. Li, A. Zand, J. Barrett, J. Ranieri, L. Invernizzi, Y. Markov, O. Comanescu, V. Eranti, A. Moscicki *et al.*, "Data breaches, phishing, or malware?: Understanding the risks of stolen credentials", in "Proceedings of the ACM Conference on Computer and Communications Security (CCS)", pp. 1421–1434 (ACM, 2017).

[104] Thomas, K., D. McCoy, C. Grier, A. Kolcz and V. Paxson, "Trafficking fraudulent accounts: The role of the underground market in twitter spam and abuse", in "Proceedings of the USENIX Security Symposium (USENIX)", (2013).

[105] USPS Office of Inspector General, "Information Security Awareness Training and Phishing", URL `https://www.uspsoig.gov/sites/default/files/document-library-files/2015/IT-AR-16-001.pdf` (2015).

[106] Verizon, "2019 Data Breach Investigations Report", Tech. rep. (2019).

[107] Verizon, "2021 Data Breach Investigations Report", Tech. rep. (2021).

[108] Wang, D., D. Pedreschi, C. Song, F. Giannotti and A.-L. Barabasi, "Human mobility, social ties, and link prediction", in "Proceedings of the ACM SIGKDD International Conference on Knowledge Discovery and Data Mining (KDD)", (2011).

[109] Wang, S. and C. D. Manning, "Baselines and bigrams: Simple, good sentiment and topic classification", in "Proceedings of Association for Computational Linguistics (ACL)", (2012).

[110] Xie, Z. and S. Zhu, "AppWatcher: Unveiling the Underground Market of Trading Mobile App Reviews", in "Proceedings of the ACM Conference on Security and Privacy in Wireless and Mobile Networks (WiSec)", (2015).

[111] Yeboah-Boateng, E. O. and P. M. Amanor, "Phishing, smishing & vishing: An assessment of threats against mobile devices", Journal of Emerging Trends in Computing and Information Sciences **5**, 4, 297–307 (2014).

[112] Zhang, M., "Couple stole $1.2m worth of cameras and electronics from amazon", URL `https://petapixel.com/2017/10/02/couple-stole-1-2m-worth-cameras-electronics-amazon/`, (Last accessed Nov 9, 2019) (2017).

[113] Zhang, P., A. Oest, H. Cho, Z. Sun, R. Johnson, B. Wardman, S. Sarker, A. Kpravelos, T. Bao, R. Wang, Y. Shoshitaishvili, A. Doupé and G.-J. Ahn, "CrawlPhish: Large-scale Analysis of Client-side Cloaking Techniques in Phishing", in "Proceedings of the IEEE Symposium on Security and Privacy", (2021).

[114] Zhao, Z., G.-J. Ahn, H. Hu and D. Mahi, "Socialimpact: systematic analysis of underground social dynamics", in "Proceedings of the European Symposium on Research in Computer Security (ESORICS)", (2012).

[115] Zhao, Z., M. Sankaran, G.-J. Ahn, T. J. Holt, Y. Jing and H. Hu, "Mules, seals, and attacking tools: Analyzing 12 online marketplaces", IEEE Security & Privacy (2016).

[116] Zheng, J., Z. He and Z. Lin, "Hybrid adversarial sample crafting for black-box evasion attack", in "Proceedings of the IEEE International Conference on Wavelet Analysis and Pattern Recognition (ICWAPR)", (2017).

[117] Zhou, Y., E. Reid, J. Qin, H. Chen and G. Lai, "Us domestic extremist groups on the web: link and content analysis", IEEE intelligent systems (2005).

APPENDIX A

WORK II: SERVICE FORM IN PREPARATION STAGE

In the preparation stage of the CAaaS, scam initiators are often requested to fill a service form, before further discussing with the scam provider. As questions in different providers' forms are similar, we show questions of a scam provider below:

Table A.1: Service form questions.

No.	Question
1	Which store do you need a refund on? Mention with domain (com/de/uk)
2	When did you place the order?
3	When did you receive your order?
4	Provide the carrier/tracking number?
5	Price of the item?
6	Your order number?
7	Name on your account?
8	The email address used for your account/order?
9	The billing address on the account? (including country & zip code)
10	The shipping address on the account? (including country & zip code)
11	Was a refund already attempted on your order? If yes, What method did you use and what did they say?
12	What type of payment? Example "Master Card" last 4 digits of the card used
13	What do you need, Refund/Replacement?
14	How do you want to pay me?
15	Did you sign for it? or was it left somewhere outside?
16	What was the item you want to get refunded? (Please paste links. In case of multiple items in your order, please include links to all and individual costs of each item)
17	Provide your telegram/discord you used to contact me.
18	Phone Number on the order/account?
19	Anything more about the order/account? Anything important that I should know?

APPENDIX B

WORK II: SCAM TUTORIALS

Table B.1 is a scammer's tutorial advertising found in the underground forum.

Table B.1: Tutorials for Concession Abuse.

Book Name	Book Type	Price	Introduction
E-Book	Core	€69.00	Introduction; Information; Q&A; Common refund methods; Amazon System explained; Internal/External Investigation explained; How to profit from refunding; Tips; Support
Fake TID method	Selective	€119.90	Best and most effective method of most shops; Step-by-step guide for Amazon
PayPal refunds up to 15,000 EUR	Selective	€179.90	New and easy way of refunding through Paypal, even if the seller is replying to your dispute. It comes with nearly 100% success rate for any store.
Amazon bonus methods	Selective	€19.90	Detailed step-by-step guide on how to refund Amazon with exclusive methods. It allows you to refund on Amazon (.com/.co.uk); How to get an instant advanced replacement for cracked accounts on Amazon.de
Find refundable stores	Selective	€39.90	A simple and extremely powerful way of finding new stores to refund
Telegram refunding group	Selective	€14.90	Come and join us! Exchange your ideas and experience with others. Connect with each other and improve your knowledge!
Start your own service	Selective	€49.90	Information for your future refund service including how to start, prepare, improve and maximize your business.
1-ON-1 mentorship	Selective	€449.90	Providing you help to complete with ongoing refunds and giving extra tips.

APPENDIX C

WORK II: SURVEY QUESTIONS AND RESULTS

Table C.1: Survey questions.

	Question	Answer Options
S1 (Invest & Proof)	***S1: If you contact a merchant for a refund/replacement WITHOUT returning goods because of a reason such as never receiving the package or receiving an empty package.***	
	Q1: Do you mind if the merchant starts an investigation before issuing the refund/replacement?	Five-point Likert scale.
	Q2: If it is a high-value good (hundreds of dollars), do you mind the investigation?	Five-point Likert scale.
	Q3: If the merchant needs to start an investigation in this scenario, would you stop buying goods from this merchant any more?	(i) Yes, I will STOP buying from it, (ii) No, I will continue buying from it
	Q4: If the merchant needs to start an investigation on high-value goods in this scenario, would you stop buying goods from this merchant any more?	(i) Yes, I will STOP buying from it, (ii) No, I will continue buying from it
	Q5: Do you mind providing extra proof in this scenario? For example, a video of the empty box with a handwritten reference number, or a police report if the package is stolen by someone?	Five-point Likert scale.
	Q6: If the merchant needs you to provide extra proof in this scenario, would you stop buying goods from this merchant any more?	(i) Yes, I will STOP buying from it, (ii) No, I will continue buying from it
	Q7: If you mind the investigation or providing extra proof in this scenario, please briefly explain the reason.	Short Answer
	Q8: If you DO NOT mind the investigation or providing extra proof, please briefly explain the reason.	Short Answer
S2 (ID_Verif)	***S2: To prevent criminals from buying goods using your account, an effective countermeasure could be verifying a customer's identity (i.e., 2-factor authentication; answer security questions through a link) when the shipping address is requested to change.***	
	Q1: Do you mind merchants employing this approach?	Five-point Likert scale.
	Q2: If the merchant employs this approach, would you stop buying goods from this merchant any more?	(i) Yes, I will STOP buying from it, (ii) No, I will continue buying from it
	Q3: If you mind the merchant employing this security approach, please briefly explain the reason.	Short Answer
	Q4: If you DO NOT mind the merchant employing this security approach, please briefly explain the reason.	Short Answer
S3 (Local_Rtn)	***S3: To ensure some high-value goods are properly packaged and avoid any unnecessary loss, customers may be requested to return them to a local store or a shipping agent who will help pack them.***	
	Q1: Do you mind merchants employing this policy?	Five-point Likert scale.
	Q2: If the merchant employs this return policy, would you stop buying goods from this merchant any more?	(i) Yes, I will STOP buying from it, (ii) No, I will continue buying from it
	Q3: If you mind the merchant employing this return policy, please briefly explain the reason.	Short Answer
	Q4: If you DO NOT mind the merchant employing this return policy, please briefly explain the reason.	Short Answer
S4 (Sep_Ship)	***S4: To track and ensure the high-value goods can be delivered to you, high-value goods would be shipped separately with your other packages.***	
	Q1: Do you mind merchants employing this policy?	Five-point Likert scale.
	Q2: If the merchant employs this policy, would you stop buying goods from this merchant any more?	(i) Yes, I will STOP buying from it, (ii) No, I will continue buying from it
	Q3: If you mind the merchant employing this shipping policy, please briefly explain the reason.	Short Answer
	Q4: If you DO NOT mind the merchant employing this shipping policy, please briefly explain the reason.	Short Answer
S5 (Pin_Egift)	***S5: To protect gift cards in customers' accounts from stealing, setting up a payment password/PIN for e-gift cards would be an effective security approach.***	
	Q1: Do you mind merchants employing this approach?	Five-point Likert scale.
	Q2: If the merchant employs this approach, would you stop buying goods from this merchant any more?	(i) Yes, I will STOP buying from it, (ii) No, I will continue buying from it
	Q3: If you mind the merchant employing this security approach, please briefly explain the reason.	Short Answer
	Q4: If you DO NOT mind the merchant employing this security approach, please briefly explain the reason.	Short Answer
S6 (Sec_Notif)	***S6: To ensure customers can receive information about all account activities even if the accounts are hacked, a dedicated notification approach, such as a secondary email address, is needed. This notification approach would be undisclosed in a customer's profile.***	
	Q1: Do you mind merchants employing this approach?	Five-point Likert scale.
	Q2: If the merchant employs this approach, would you stop buying goods from this merchant any more?	(i) Yes, I will STOP buying from it, (ii) No, I will continue buying from it
	Q3: If the merchant needs your secondary email address as the notification approach, do you have a secondary e-mail address you could provide?	(i) Yes, (ii) No
	Q4: If you mind the merchant employing this security approach, please briefly explain the reason.	Short Answer
	Q5: If you DO NOT mind the merchant employing this security approach, please briefly explain the reason.	Short Answer

Table C.2: Demographics of participants.

	Metric	Percentage of Participants
Gender	Female	53.8%
	Male	44.9%
	No Answer	1.3%
Age	18 ∼ 29 years	12.3%
	30 ∼ 49 years	62.7%
	50+ years	25.0%
Education	Up to H.S.	10.1%
	Some College	31.8%
	B.S. or above	58.1%
Num of shopping acct	0	0.8%
	1 ∼ 3	35.2%
	4 ∼ 6	31.8%
	7+	32.2%
Freq. of shopping per month	0	0.4%
	1 ∼ 3	60.2%
	4 ∼ 6	21.6%
	7+	17.8%
Expense of shopping in 2019	¡= $200	7.6%
	$201 ∼ $500	22.9%
	$501 ∼ $1,000	29.7%
	$1,000+	39.8%

Table C.3: General security experience and attitude.

	Metric	Percentage of Participants
Account Hacked (or suspected to be hacked)	Yes	40.3%
	No	59.7%
Financial Loss	Yes	3.4%
	No	96.6%
Adopt Security Measure	1 (Strongly disagree)	0.8%
	2	3.4%
	3	11.0%
	4	32.6%
	5 (Strongly agree)	52.2%

Table C.4: Participants' concerns about security approaches.

Scenario	Concern	Quote
Invest & Proof	Inconvenience	I don't like being further inconvenienced to prove that I've been inconvenienced.
	Hard to prove	Hard to proof the absence of something, like a delivery. This feels like an additional burden.
	Suspecting moral character	I would not be dishonest in such a case and would be outraged that my honesty would be in question in such a case.
	Not always	It depends on how much proof they need and how easily i can get it to them. also how long they take to respond
ID_Verif	Annoying	Inconvenient and annoying and time-wasting.
Local_Rtn	Inconvenience	I live too far from these types of places for it to be remotely convienent.
	Not always	It depends on how close the store is, whether this would work.
Sep_Ship	Shipping delay	If it delays my shipment I would mind.
	Resource waste	It seems like a waste of packaging and we already waste a lot on packaging/shipping.
Pin_Egift	Annoying	Hard for me to remember regular passwords as it is but now I would have to remember a separate one for the gift cards.
Sec_Notif	Annoying	This is a pain. I don't want to main two email addresses for online shopping.
	Sharing private email address	I use one of my emails for very close and important emails and the other for shopping. I would not want any store whatsoever to have my private email under any circumstances.

Table C.5: Participants' attitudes toward security approaches.

Scenario	Security Approach	1 (Strongly Not Mind)	2	3	4	5 (Strongly Mind)	Mean	Continue Buying	Stop Buying
1	Invest	56.4%	25.4%	11.4%	4.2%	2.6%	1.71	86.9%	13.1%
1	Invest_HV	72.0%	15.7%	5.5%	3.8%	3.0%	1.5	90.2%	9.8%
1	Proof	38.6%	19.1%	17.8%	14.0%	10.6%	2.40	68.6%	31.4%
2	ID_Verif	76.3%	14.0%	4.7%	3.0%	2.1%	1.42	93.6%	6.4%
3	Local_Rtn	47.5%	17.8%	14.8%	10.2%	9.7%	2.17	86.0%	14.0%
4	Sep_Ship	81.4%	7.6%	5.5%	3.0%	2.5%	1.38	93.6%	6.4%
5	Pin_Egift	78.0%	9.7%	5.1%	4.7%	2.5%	1.44	92.4%	7.6%
6	Sec_Notif	61.9%	16.1%	8.9%	7.6%	5.5%	1.79	87.7%	12.3%

APPENDIX D

WORK II: SERVICE LIST OF A SCAM SERVICE PROVIDER

Table D.1 shows a provider's service list discussed in Section 4.4.2.

To have a better understanding of the CAaaS, we conducted a case study of a reputable service provider identified from the SENet forum. He started to provide the service since 2017 with top 1% reputation in the forum. Table D.1 shows a part of his service list. *Limit* shows the maximum value he is confident to refund, and *Items* means the number of items the provider can work in one order. The commission fee is shown in *Rate*. *Region* and *Avg Time* indicate the shipping address of the refunding order and the average time needed to receive the concession confirmation email.

Table D.1: A Concession Abuse service list.

Store Category	Payment Method	Store	Limit ($/€)	Items	Pay Rate (%)	Region	Avg Time
Clothing	Credit/Debit Card	Abercrombie & Fitch	No Limit	Multi	25%	Worldwide	1 Day
		Macys	No Limit	One	25%	USA	1 Day
		Hollister	No Limit	Multi	25%	Worldwide	1 Day
		Zappos incl Luxury	30,000	Multi	25%	USA	1 Day
		Armani	3,000	Multi	25%	Worldwide	10 Day
	PayPal	Stone Island	No Limit	Multi	15 – 25%	Worldwide	2 – 3 Weeks
		StockX	No Limit	One	15 – 25%	Worldwide	2 – 3 Weeks
		YOOX	No Limit	Multi	15 – 25%	Worldwide	2 – 3 Weeks
		Dolce Gabbana	No Limit	Multi	15 – 25%	Worldwide	2 – 3 Weeks
		Mr Porter	No Limit	Multi	15 – 25%	Worldwide	2 – 3 Weeks
Electronics	Credit/Debit Card	Walmart	30,000	Multi	25%	USA	1 Day
		Target	30,000	Multi	25%	USA	1 Day
		Google Express	12,000	One	25%	USA	5 – 10 Days
		Apple	5,000	One	25%	USA	1 – 3 Days
		Lenovo	5,000	One	25%	USA	1 – 2 Weeks
	PayPal	Canon	No Limit	Multi	15 – 25%	Worldwide	2 – 3 Weeks
		Dell	No Limit	One	15 – 25%	Worldwide	2 – 3 Weeks
		Microsoft	No Limit	Multi	15 – 25%	EU/USA/CA	2 – 3 Weeks
		Google Express	No Limit	Multi	15 – 25%	Worldwide	2 – 3 Weeks
		HP	No Limit	Multi	15 – 25%	Worldwide	2 – 3 Weeks
Beauty	Credit/Debit Card	Sephora	3,000	Multi	15 – 25%	Worldwide	1 – 5 Days
		Lancome	1,000	Multi	15 – 25%	USA	3 – 10 Days
		MAC Cosmetics	1,000	Multi	15 – 25%	Worldwide	3 – 10 Days
		Urban Decay	1,000	Multi	15 – 25%	USA	3 – 10 Days
		Estee Lauder	1,000	Multi	15 – 25%	USA	3 – 10 Days
Outdoors	Credit/Debit Card	Fanatics	1,000	Multi	15 – 25%	USA	1 Day
		NBA/NFL/NHL Store	1,000	Multi	15 – 25%	USA/CA	1 Day
		Oakley	1,000	Multi	15 – 25%	Worldwide	5 – 7 Days
		Rayban	1,000	Multi	15 – 25%	Worldwide	1 – 3 Days
		Sunglass Hut	1,000	Multi	15 – 25%	USA	3 – 10 Days
Home	Credit/Debit Card	Allmodern	No Limit	One	18 – 25%	USA/CA	1 – 5 Days
		Wayfair	No Limit	One	18 – 25%	USA/CA	1 – 5 Days
		Birch Lane	No Limit	One	18 – 25%	USA/CA	1 – 5 Days
		Joss & Main	No Limit	One	18 – 25%	USA/CA	1 – 5 Days
		Herman Miller	No Limit	One	18 – 25%	USA/CA	1 – 5 Days
Pet Store	Credit/Debit Card	Chewy	1,000	Multi	15 – 25%	USA/CA	1 – 5 Days
		PetCo	1,000	Multi	15 – 25%	USA/CA	1 – 5 Days
		PetSmart	1,000	Multi	15 – 25%	USA/CA	1 – 5 Days
		Petvalu	1,000	Multi	15 – 25%	USA/CA	1 – 5 Days
		PetSupermarket	1,000	Multi	15 – 25%	USA/CA	1 – 5 Days
Adult	Credit/Debit Card	Adam & Eve	1,000	Multi	15 – 25%	USA	1 Day
		Lovehoney	1,000	Multi	15 – 25%	Worldwide	1 Day
Amazon	Credit/Debit Card	Amazon.com	7,000	Multi	25%	Worldwide	2 – 3 Weeks
		Amazon.fr	5,000	Multi	25%	Worldwide	7 – 10 Days
		Amazon.ca	5,000	Multi	25%	Worldwide	2 – 3 Weeks
		Amazon.de	5,000	Multi	25%	Worldwide	2 – 3 Weeks
		Amazon.it	5,000	Multi	25%	Worldwide	2 – 3 Weeks
		Amazon.nl	5,000	Multi	25%	Worldwide	3 – 5 Days
		Amazon.com.au	3,000	Multi	25%	Worldwide	5 – 10 Days